Evalation Hardening Review

Detailed findings by discipline · Repository: davidleberknight/footbag-platform

Assessed	Disciplines read	Findings	Read by
2026-11-10	18	41	Opus 5.5

3	9	15	14	0	14
Critical	High	Medium	Low	Info	Positive

HARDNESS SCORE **87** /100 · grade A

The work done

We read the repository against 18 disciplines and found 41 findings, along with 14 controls working as intended. Each discipline has a section of its own, including any that found nothing. Within a section, findings run in priority order, and each names the model that found it, the file and lines it rests on, whether a second check confirmed it, and the fix. We read the code without running it and changed nothing.

Scans run

All 4 scans ran.

DEPENDENCY ADVISORIES	trivy found 134
BILL OF MATERIALS	syft counted 340 components
STATIC ANALYSIS	semgrep found 720
SECRET SCAN	gitleaks found 0

Executive summary

PURPOSE

Tests whether the code would hold up in the real world, across 18 areas: what an attacker could reach, what breaks when a service it relies on fails, what could go wrong without anyone noticing, and what works only because somebody wrote it down. Each finding points to the file and line it rests on, since a risk nobody can find in the code is one nobody can act on.

WHAT THE FINDINGS SHOW

The code is strong on sign-in and session safety: a member's role is read fresh from the database on each request, a password change signs out old sessions, and test-only shortcuts refuse to run in production.

Its safety nets are also solid: the database is copied every five minutes, the audit trail cannot be rewritten, and the build fails on dropped test coverage, switched-off tests or accessibility faults.

The template engine and a legacy data tool package carry known published flaws, and the build warns about such flaws without stopping, lets package install scripts run, and has no rule against dangerous code patterns.

Calls to Amazon's services and the payment provider set no time limit, so a stalled provider could hang a request or a background worker, and retries keep hitting a failing provider on a fixed schedule.

What the gaps share is that many protections depend on people remembering a rule, with no build check or code to catch a slip.

41 findings across 18 disciplines. The 3 critical and 9 high findings are the ones that change the risk.

Dependency advisories, Security under attack and Resilience and failure modes carry the most risk, counting each finding by its severity. Dependency advisories alone has 6 of the 41 findings, including 2 critical and 2 high. 3 findings are critical, meaning a control is missing altogether, so start there. 9 are high, where a control is in place and fails. The other 29 are medium, low or info.

Fixing the 3 critical and 9 high findings removes the serious risk, and the other 29 are lower-priority hardening. Each finding names the change that fixes it. Dependency advisories, Security under attack and Resilience and failure modes hold 17 of the 41 findings between them.

BY SECTION

SECTION	CRITICAL	HIGH	MEDIUM	LOW	POSITIVE	TOTAL
Dependency advisories	2	2	0	2	0	6
Security under attack	1	0	0	0	1	1
Security defences	0	3	0	0	1	3
Resilience and failure modes	0	2	5	1	1	8
Privacy and supply chain	0	1	1	0	0	2
API and contract design	0	1	1	0	0	2
Compliance and governance	0	0	3	1	1	4
Disaster recovery and durability	0	0	2	0	2	2
Code quality	0	0	1	2	0	3
Algorithm correctness	0	0	1	1	1	2
Observability and service levels	0	0	1	0	1	1
Documentation and operations	0	0	0	4	0	4
Reliability and testing	0	0	0	2	3	2
Performance and cost	0	0	0	1	1	1
Architecture	0	0	0	0	1	0

BY SECTION, CONTINUED

SECTION	CRITICAL	HIGH	MEDIUM	LOW	POSITIVE	TOTAL
Accessibility and usability	0	0	0	0	1	0
Documentation (wiki)	0	0	0	0	0	0
AI and prompts	0	0	0	0	0	0
Total	**3**	**9**	**15**	**14**	**14**	**41**

MOST SERIOUS

CVE-01	certifi in the legacy data tools trusts revoked certificate authorities	CRITICAL
CVE-02	handlebars 4.7.9 carries critical code injection advisories	CRITICAL
XSEC-01	Build accepts eval and new Function	CRITICAL
API-01	Request bodies reach services without a schema check	HIGH
CVE-03	New advisories reach nobody until a push or a requested report	HIGH
CVE-04	The CI dependency audit never fails the build	HIGH
PRIV-01	Package install scripts run unchecked in CI and image builds	HIGH
RES-01	AWS SDK calls can wait without end	HIGH
RES-02	SQS feed calls set no client timeout	HIGH
SEC-01	Raw template output for links and bodies carries no marker	HIGH
SEC-02	Error pages give callers no reference to quote	HIGH
SEC-03	Weak hashes and certificate checks have no build rule	HIGH
ALG-01	Active Player expiry is untested at the expiry moment	MEDIUM
API-02	The web side keeps its own copy of the image worker reply shape	MEDIUM
COMP-01	Account deletion leaves the Stripe customer record	MEDIUM
COMP-02	Governance rules name no enforcing code or test	MEDIUM

And 25 more in the sections that follow.

POINTS TO WEIGH

- Ask whether the template engine has been updated to the release that fixes its published code injection flaws, and whether the build will be made to stop on such flaws.
- Check how new security advisories would reach anyone during a quiet period when no code is being pushed.
- Ask what happens to sign-in, email and uploads if an Amazon service stops answering, given that no time limit is set on those calls.
- Consider whether erasing a member should also remove their record held by the payment provider, and how the platform would show that logs hold no personal data.
- Ask how a reviewer can tell which of the 84 unescaped template outputs could ever show text a member typed in.
- Check when a database restore last worked and how long it took, since that proof lives outside this repository.

Reading a finding

Each finding below is laid out this way.

ID	The discipline's prefix and the finding's place in the priority order.
HEADLINE	The finding in one sentence, with the detail beneath it.
SEVERITY	Critical to Info on the coloured tag, and Positive for a control found working.
PRIORITY	P0 do first · P1 near-term · P2 should-fix · P3 cleanup.
MODEL	The model that found it.
WHERE IT RESTS	The file and lines on the grey bar.
STANDING	Scanned where a scanner found it · verified where a second check confirmed it against the repository · asserted where nothing did.
THE FIX	The fix, on the orange bar.

Security defences (4): C 0 | H 3 | M 0 | L 0 | I 0 | P 1

Read for untrusted input reaching an interpreter, who may do what, decided in one place, credentials that never reach a file or a log, what happens when nobody configured it, among others.

SEC-01 Handlebars views print values unescaped in 84 places.

P1 · Opus 5.5 HIGH

JSON data islands come from named builders, and links such as `{{{href}}}` and markdown bodies such as `{{{content.doc.bodyHtml}}}` carry no comment or helper saying why each is safe. A reviewer cannot tell which of these could ever hold member text, and one that did would let a member run script in another visitor's browser.

`src/views/ifpa/detail.hbs:23` VERIFIED

THE FIX

Route raw output through named helpers that say what they produce, or add a comment on each use naming the trusted source, and add a check that fails on an unmarked triple brace.

SEC-02 The last error handler logs the failure and shows a fixed page, and the page carries no error id.

P1 · Opus 5.5 HIGH

A member who reports a fault cannot point support at the matching log line, so tracing an incident means searching logs by time and guesswork.

`src/lib/controllerErrors.ts:162-167` VERIFIED

THE FIX

Generate an id for each unhandled error, write it in the log line and show it on the error page.

SEC-03 CodeQL runs the security-extended queries, and its job passes whatever alerts it raises.

P1 · Opus 5.5 HIGH

Lint has no rule on MD5, SHA-1 or turned off certificate checks. A change that hashes a secret with SHA-1 or sets rejectUnauthorized to false would merge with a green build.

Continued on page 5

SECURITY DEFENCES, SEC-03, CONTINUED

SEC-03 CodeQL runs the security-extended queries, and its job passes whatever alerts it raises, continued

.github/workflows/ci.yml:432-433 VERIFIED

THE FIX

Make the CodeQL step fail on alerts at high severity, or add lint or convention checks that refuse MD5, SHA-1 and DES in security code and refuse rejectUnauthorized set to false.

SEC-04 The session middleware verifies the signed cookie and then reads the role from the member row, ignoring the role claim in the token. Opus 5.5 POSITIVE

Tests show a token claiming administrator for a plain member resolves to member.

src/middleware/auth.ts:130-140 VERIFIED

WORTH KEEPING

The role check reads `is_admin` from the current row. Reading `claims.role` for authorisation would let a demoted administrator keep power until the token expires.

Security under attack (2): C 1 | H 0 | M 0 | L 0 | I 0 | P 1

Read for text that becomes an instruction, what the operating identity could do if it were turned, something that runs enforces the control, anything the repository causes to run.

XSEC-01 Lint has no no-eval or no-new-func rule, and the convention gate has no pattern for them. P0 · Opus 5.5 CRITICAL

Today's code holds neither, yet a future change adding eval on request data would pass the build and open the server to code injection.

eslint.config.mjs:25-33 VERIFIED

THE FIX

Add no-eval, no-implied-eval and no-new-func as errors in eslint.config.mjs.

XSEC-02 The cheap password hashing switch stops start up unless the Vitest runner set it, so a stray setting cannot weaken stored passwords in production. Opus 5.5 POSITIVE

src/config/env.ts:615-621 VERIFIED

Continued on page 6

SECURITY UNDER ATTACK, XSEC-02, CONTINUED

XSEC-02 The cheap password hashing switch stops start up unless the Vitest runner set it, so a stray setting cannot weaken stored passwords in production, continued

WORTH KEEPING

Start up keys the check on `process.env.VITEST`. Keying it on NODE_ENV would break it, since tests set NODE_ENV to production.

Architecture (1): C 0 | H 0 | M 0 | L 0 | I 0 | P 1

Read for the one thing whose loss stops everything, two of something running at once, which way it fails when it cannot tell, stopping in the middle.

ARCH-01 **When the human check cannot answer, sign in, registration and password reset answer 503 and change nothing, and a test covers each form.** Opus 5.5 POSITIVE

tests/integration/auth-captcha.routes.test.ts:268-275 VERIFIED

WORTH KEEPING

The gate treats an unavailable verifier as a refusal. Mapping that outcome to a pass would let bots through whenever the verifier is down.

Code quality (3): C 0 | H 0 | M 1 | L 2 | I 0 | P 0

Read for what happens to a failure nobody expected, the same rule written in two places, code nothing reaches any more.

QUAL-01 **Lint has no no-empty rule and ignores caught errors.** P2 · Opus 5.5 MEDIUM

Catch blocks that swallow failures, such as the storage lookups in the local media adapter, pass the build, so a new one could hide a real fault.

src/adapters/mediaStorageAdapter.ts:130-135 VERIFIED

THE FIX

Turn on no-empty with allowEmptyCatch false and give each deliberate empty catch a comment the rule accepts.

QUAL-02 **Environment switches such as `ALLOW_CURATED_SIDECAR_WRITES` carry no date or release for removal.** P3 · Opus 5.5 LOW

Temporary switches tend to stay, and the code behind the dormant branch keeps costing review time.

Continued on page 7

CODE QUALITY, QUAL-02, CONTINUED

QUAL-02 Environment switches such as `ALLOW_CURATED_SIDECAR_WRITES` carry no date or release for removal, continued

src/config/env.ts:700-710 VERIFIED

THE FIX

Record a removal date or release beside each temporary switch and fail CI once it passes.

QUAL-03 Lint has no rule on repeated literals and CI has no duplicate code check. P3 · Opus 5.5 LOW

Developers keep row types by hand as a second copy of the schema. Drift between copies shows up only when a test happens to catch it.

eslint.config.mjs:25-33 VERIFIED

THE FIX

Add a duplicate code check such as jscpd to CI, and generate row types from database/schema.sql.

Privacy and supply chain (2): C 0 | H 1 | M 1 | L 0 | I 0 | P 0

Read for what personal data it holds and why, what escapes in a log, an error or a sample, what it depends on, pinned and accounted for.

PRIV-01 Each CI job that installs packages, and the Docker builder stage, runs npm ci with package install scripts enabled. P1 · Opus 5.5 HIGH

A compromised dependency or one of its own dependencies can run code on the CI runner or inside the image build. Left alone, one poisoned release reaches the build with no gate.

.github/workflows/ci.yml:47-48 VERIFIED

THE FIX

Run npm ci with --ignore-scripts, then rebuild only the packages that need native builds, such as better-sqlite3, argon2 and sharp, through an explicit allow list.

PRIV-02 The project summary says the governance document records each field's purpose, and that document gives purposes by activity. P2 · Opus 5.5 MEDIUM

Phone, WhatsApp and address columns have no stated purpose, so a member asking why the platform holds one may get no written answer.

Continued on page 8

PRIV-02 The project summary says the governance document records each field's purpose, and that document gives purposes by activity, continued

docs/PROJECT_SUMMARY.md:660 VERIFIED

THE FIX

Add a register to docs/DATA_GOVERNANCE.md giving each personal field its purpose, retention and recipients.

Reliability and testing (5): C 0 | H 0 | M 0 | L 2 | I 0 | P 3

Read for whether a test would fail if the code were wrong, tests that depend on the world, the paths nothing exercises.

REL-01 Tests draw names and ids from Math.random and randomUUID with no seed, and no test controls the randomness inside the code under test.

P3 · Opus 5.5 LOW

A failure tied to one random value can vanish on the next run and resist reproduction.

tests/fixtures/testDb.ts:44-45 VERIFIED

THE FIX

Derive test names from the printed file order seed or a seeded generator, and inject the random source into code paths whose output tests compare.

REL-02 No mutation tool runs, and docs/TESTING.md records a choice against whole-suite mutation testing.

P3 · Opus 5.5 LOW

Tests that pass whatever the code does can survive unnoticed outside the patterns the convention gate greps for.

docs/TESTING.md:1123-1128 VERIFIED

THE FIX

Run a mutation tool such as Stryker on the payment, sign in and deletion services on a schedule, and review surviving mutants.

REL-03 Vitest shuffles file order on each run and prints the seed, so tests that depend on order surface in CI and anyone can replay the failing order.

Opus 5.5 POSITIVE

vitest.config.ts:89-90 VERIFIED

WORTH KEEPING

The sequence setting in vitest.config.ts provides this. Turning the shuffle off would hide order dependence again.

RELIABILITY AND TESTING, CONTINUED

REL-04 vitest.config.ts sets statement, branch, function and line floors, and the CI coverage job runs the suite against them.

Opus 5.5 POSITIVE

A change that removes tested paths fails the build.

vitest.config.ts:135-140 VERIFIED

WORTH KEEPING

The thresholds block in vitest.config.ts and the CI coverage step hold this. Lowering the numbers or dropping the coverage flag would end the check.

REL-05 The convention gate greps tests/ for .skip, .todo and xit and fails CI on any hit.

Opus 5.5 POSITIVE

A test switched off to get a change through cannot land silently.

scripts/ci/assert_conventions.sh:953-961 VERIFIED

WORTH KEEPING

The grep in scripts/ci/assert_conventions.sh and the conventions job in CI enforce this. Removing either job or adding an exemption pattern would let skipped tests through.

Performance and cost (2): C 0 | H 0 | M 0 | L 1 | I 0 | P 1

Read for what gets slower as it is used, what each operation costs to run, what accumulates and is never removed.

PERF-01 The live link reachability adapter stores each checked address in a map with a 24 hour expiry.

P3 · Opus 5.5 LOW

Nothing removes expired entries or caps the map, so memory grows with every distinct address until the process restarts.

src/adapters/httpReachabilityAdapter.ts:77 VERIFIED

THE FIX

Delete an entry once it expires and cap the map at a fixed size, dropping the oldest entries first.

PERF-02 The monthly AWS budget mails the operator at 80 percent of actual spend and again when the forecast passes the limit, so a runaway cost shows up early in the month.

Opus 5.5 POSITIVE

terraform/production/budgets.tf:31-57 VERIFIED

WORTH KEEPING

The aws_budgets_budget resource in terraform/production/budgets.tf provides this. Deleting it or pointing it at an unread address would end the warning.

Compliance and governance (5): C 0 | H 0 | M 3 | L 1 | I 0 | P 1

Read for a control asserted and not implemented, what was done, by whom, provable afterwards, getting rid of something on request.

COMP-01 The purge sets the local Stripe customer id to null and makes no call to Stripe.

P2 · Opus 5.5 **MEDIUM**

Stripe keeps the member's name, email and payment history after the member asks for erasure.

`database/schema.sql:2455` VERIFIED

THE FIX

Call the Stripe customer deletion interface from the purge job once payment records pass their legal retention, and record the call in the erasure log.

COMP-02 A search of docs/DATA_GOVERNANCE.md for tests/, src/, terraform/ and scripts/ finds no path, so none of its rules points to what enforces it.

P2 · Opus 5.5 **MEDIUM**

In docs/TESTING.md section 4.8 the cross-cutting rule register has nine rows. Four of them name an existing test (the member-state mail, authentication and listings sweeps, and the real-data invariants), one names an existing classification test with its stripping test marked to build, and four are marked to build. Section 8 of the governance document, whose logging rules include that logs never carry raw email addresses or tokens, has no register row, so a reviewer cannot tell from the documents what enforces those rules.

`docs/DATA_GOVERNANCE.md:79-82` VERIFIED

THE FIX

Add a register row in docs/TESTING.md, or a line under each rule in docs/DATA_GOVERNANCE.md, naming the file, Terraform resource or test that enforces it, and mark rules with no enforcement as planned.

COMP-03 The logger writes any metadata a caller passes, and no test or CI check scans log output for email addresses, tokens or passwords.

P2 · Opus 5.5 **MEDIUM**

One careless log call would put member addresses into CloudWatch for 90 days.

`src/config/logger.ts:60-64` VERIFIED

THE FIX

Add a test hook that captures logger output across the suite and fails on any email address, token or password pattern, or filter those fields inside the logger.

COMP-04 Sign in writes an audit row only when a lockout starts (auth.login_rate_limited, src/services/identityAccessService.ts line 699).

P3 · Opus 5.5 **LOW**

A successful sign in writes a log line auth.login_success with the member id (src/controllers/authController.ts line 96), kept 90 days in the production app log group (terraform/production/cloudwatch.tf line 12), and overwrites members.last_login_at (src/db/db.ts line 4582). Past 90 days nothing records the earlier sign ins of an account, so an investigation of a taken over account has only the latest sign in time.

Continued on page 11

COMPLIANCE AND GOVERNANCE, COMP-04, CONTINUED

COMP-04 Sign in writes an audit row only when a lockout starts (auth.login_rate_limited, src/services/identityAccessService.ts line 699), continued

src/services/identityAccessService.ts:699 VERIFIED

THE FIX

Write an audit row on each successful sign in naming the member and time, with the address hashed as the lockout row does.

COMP-05 Two triggers on audit_entries abort any update and any delete of a row younger than seven years. Opus 5.5 POSITIVE

Application code cannot rewrite or remove recent audit history.

database/schema.sql:1084-1101 VERIFIED

WORTH KEEPING

The triggers in database/schema.sql enforce this. A migration that drops them, or a raised retention floor set below seven years in the trigger, would remove the protection.

Accessibility and usability (1): C 0 | H 0 | M 0 | L 0 | I 0 | P 1

Read for whether the interface can be used without a mouse or sight, what a person sees when it is loading, empty or broken.

UX-01 Playwright runs axe WCAG 2.1 AA scans over public, member and admin pages, and a separate rule measures text contrast across the site's views. Opus 5.5 POSITIVE

A new missing label or a new contrast failure fails the build.

tests/e2e/helpers/axe.ts:30-38 VERIFIED

WORTH KEEPING

The axe helper and the contrast rule in tests/e2e/helpers run under the e2e and rendered style CI jobs. Removing those jobs or widening the disabled rule list would weaken the check.

Documentation and operations (4): C 0 | H 0 | M 0 | L 4 | I 0 | P 0

Read for where the documentation is wrong, whether somebody new could build and run it, what to do when it is broken at three in the morning.

DOC-01 The README quickstart gives setup, running and testing but never says how to build the TypeScript or the container images.

P3 · Opus 5.5 LOW

A newcomer preparing a deploy has to find npm run build and the Dockerfiles alone.

README.md:33-39 VERIFIED

THE FIX

Add a build line to the README quickstart naming npm run build and the image build command.

DOC-02 The readiness script expects incident write ups under evidence/postmortems/, and the folder does not exist.

P3 · Opus 5.5 LOW

Past failures and their fixes appear only in code comments and the private repository.

scripts/production-readiness-sitting.sh:153 VERIFIED

THE FIX

Commit a short write up per incident under evidence/postmortems/ with the cause, the fix and the follow up.

DOC-03 No CI step runs the quickstart commands in README.md.

P3 · Opus 5.5 LOW

A renamed script or changed flag breaks the first steps a newcomer takes, and nothing reports it.

README.md:33-39 VERIFIED

THE FIX

Add a CI job that runs the README quickstart on a clean runner and fails when any command fails.

DOC-04 docs/DATA_MODEL.md describes the schema by hand, and no generator builds reference pages from database/schema.sql or the services.

P3 · Opus 5.5 LOW

The hand copy can fall behind the schema.

database/README.md:11 VERIFIED

THE FIX

Generate a table and column reference from database/schema.sql in CI and fail when the committed copy differs.

Documentation (wiki) (0): C 0 | H 0 | M 0 | L 0 | I 0 | P 0

Read for whether the intended behaviour is written down anywhere.

The reading found nothing to report.

AI and prompts (0): C 0 | H 0 | M 0 | L 0 | I 0 | P 0

Read for instructions to a model, read as a contract, what happens when the answer is not the shape expected, testing a change to a prompt.

The reading found nothing to report.

Algorithm correctness (3): C 0 | H 0 | M 1 | L 1 | I 0 | P 1

Read for the logic everything else rests on, off by one, and ties.

ALG-01 Benefits end when the expiry is no longer later than now, by a strict comparison.

P2 · Opus 5.5 MEDIUM

Tests check thirty days ahead, a day past and the year 2000, so a change to an inclusive comparison would pass them.

`tests/integration/tierPredicates.active-player-edge-cases.test.ts:75-86` VERIFIED

THE FIX

Add tests with a fixed clock at the expiry instant and one millisecond either side, asserting benefits end at the instant.

ALG-02 The tier predicates have fixed case tests for each tier state.

P3 · Opus 5.5 LOW

Generated cases would catch combinations of tier, admin flag, Active Player expiry and missing members that the table leaves out.

`src/services/tierPredicates.ts:44-50` VERIFIED

THE FIX

Add a fast-check property test asserting that hasTier1Benefits holds whenever isTier2Plus holds and that admins pass each predicate.

ALG-03 Integration tests walk each tier state through each predicate using the real tiering writes, and a second file covers Active Player edge states.

Opus 5.5 POSITIVE

`tests/integration/tierPredicates.service.test.ts:1-10` VERIFIED

WORTH KEEPING

The table depends on new tier states being added to tests/integration/tierPredicates.service.test.ts. A new state without a row would go untested.

Resilience and failure modes (9): C 0 | H 2 | M 5 | L 1 | I 0 | P 1

Read for each external thing, and what its failure does, a wait with no end, retrying into a wall.

RES-01 The SES, S3, KMS and Parameter Store clients are built without a request timeout.

P1 · Opus 5.5 HIGH

A stalled connection to AWS would hold an email send, an upload or a session signing until the operating system gives up, and the outbox drain or the request would hang with it.

`src/adapters/sesAdapter.ts:107-112` VERIFIED

THE FIX

Pass a request handler with connection and request timeouts to each AWS client, for example NodeHttpHandler with requestTimeout of a few seconds.

RES-02 The notification feed client sets no request timeout, and the delete call passes no abort signal.

P1 · Opus 5.5 HIGH

A hung connection would stop the worker from reading SES feedback and alarm events.

`src/adapters/notificationFeedAdapter.ts:65-76` VERIFIED

THE FIX

Give the SQSClient a request handler timeout longer than the twenty second poll, and pass an abort signal with a deadline to deleteMessage.

RES-03 Tests make Turnstile, Safe Browsing and the image and video workers hang past their time limits, and feed unreadable bodies to Turnstile and the queued email feedback.

P2 · Opus 5.5 MEDIUM

The adapters for SES, S3, KMS, Parameter Store, SQS and Stripe build their clients without setting a request time limit of their own, and no test makes those clients hang. A slow provider could hold a web request or a worker pass for as long as each client library waits by default, and a change in how that failure surfaces would go unnoticed.

`src/adapters/sesAdapter.ts:107-112` VERIFIED

THE FIX

Set a request time limit on each of those clients, and add adapter tests that make each one hang past it and assert the adapter's typed error.

RES-04 The outbox and the backup upload wait fixed powers of two between attempts.

P2 · Opus 5.5 MEDIUM

After a shared outage, queued sends all retry at the same moments and hit the provider together.

`src/services/communicationService.ts:1081-1082` VERIFIED

Continued on page 15

RESILIENCE AND FAILURE MODES, RES-04, CONTINUED

RES-04 The outbox and the backup upload wait fixed powers of two between attempts, continued

THE FIX

Add a random amount to each wait, for example a delay picked between half and the full backoff value.

RES-05 The outbox, Turnstile and Safe Browsing paths call their provider on each attempt with nothing that stops calls after repeated failures.

P2 · Opus 5.5 MEDIUM

During an outage each request pays the full timeout before failing.

src/adapters/captchaAdapter.ts:142-150 VERIFIED

THE FIX

Add a small breaker in the adapters for SES, Turnstile and Safe Browsing that skips calls for a short period after several failures in a row and logs the open state.

RES-06 The workflow sets timeout-minutes on no job, so a hung test or install runs for GitHub's six hour default and blocks the merge verdict.

P2 · Opus 5.5 MEDIUM

.github/workflows/ci.yml:79-81 VERIFIED

THE FIX

Add timeout-minutes to each job in .github/workflows/ci.yml, sized a little above its usual run time.

RES-07 classifySendError returns 'failure' for any error that is not a throttle or a timeout or connection error, including a definitive provider rejection.

P2 · Opus 5.5 MEDIUM

The drain retries a failure with exponential backoff until retry_count reaches outbox_max_retry_attempts, seeded at 5. With the seeded outbox_retry_base_seconds of 60, an address SES refuses for good is sent five times over about 15 minutes (waits of 60, 120, 240 and 480 seconds) before reaching the dead letter state.

src/services/communicationService.ts:404-434 VERIFIED

THE FIX

Send recognised permanent rejections, such as a rejected message or an invalid address, straight to the dead letter state, and retry unknown and passing errors alone.

RESILIENCE AND FAILURE MODES, CONTINUED

RES-08 **The design decisions name five AWS services in one place and cover Stripe and Turnstile elsewhere.** P3 · Opus 5.5 LOW

SQS, Safe Browsing and the image worker appear nowhere in that list, and most services have no stated behaviour when down.

`docs/DESIGN_DECISIONS.md:4027` VERIFIED

THE FIX

Add one table to the design decisions naming each outside service and store with what the site does when it is down, slow or throttling.

RES-09 **The scheduler races each job against a ten minute limit, logs an overrun and moves to the next job, so one stuck job cannot starve the rest.** Opus 5.5 POSITIVE

`src/services/jobRegistry.ts:257-263` VERIFIED

WORTH KEEPING

The limit works through withinLimit in src/services/jobRegistry.ts. Removing the race would let one hung job block each later job.

Dependency advisories (6): C 2 | H 2 | M 0 | L 2 | I 0 | P 0

Read for dependencies with advisories against them, how a new advisory would be noticed.

CVE-01 **legacy_data/requirements.txt pins certifi 2026.2.25, whose bundle still trusts an emSign root with compromised intermediate keys.** P0 · Opus 5.5 CRITICAL

Scripts using it could accept a forged certificate when they fetch from the network.

`legacy_data/requirements.txt:1-456` SCANNED

THE FIX

Pin certifi 2026.10.18 or later in legacy_data/requirements.txt and refresh its hashes.

CVE-02 **package-lock.json pins handlebars 4.7.9, the template engine behind express-handlebars on the web server.** P0 · Opus 5.5 CRITICAL

The scan reports critical advisories for JavaScript injection, fixed in 4.7.10. Left in place, a crafted template input could run code on the server.

`package-lock.json:5972-5973` SCANNED

THE FIX

Raise handlebars to 4.7.10 or later through an override in package.json, regenerate package-lock.json and rerun the scan.

DEPENDENCY ADVISORIES, CONTINUED

CVE-03 Repository-level vulnerability alerting is off by design, and .github/workflows/ci.yml, the only workflow, triggers on push and on pull requests to main with no schedule trigger.

P1 · Opus 5.5 HIGH

Its dependency audit and pull-request dependency review report as warnings only. An advisory published against a deployed package while nothing is pushed stays unseen until the next push or until the maintainer runs a report on request.

`docs/DESIGN_DECISIONS.md:4885` VERIFIED

THE FIX

Schedule scripts/check-vulnerabilities.sh or an audit job in CI to run weekly and send its result to the alarm address, or turn on Dependabot alerts without automatic pull requests.

CVE-04 The audit step turns any finding into a warning annotation, so a change can merge while critical advisories sit in the lockfile.

P1 · Opus 5.5 HIGH

Today's scan shows such advisories.

`.github/workflows/ci.yml:97-101` VERIFIED

THE FIX

Make the audit step fail on critical and high advisories, with an allow list file naming each accepted advisory and its reason.

CVE-05 The vulnerability report says patching is best effort with no deadline, so a critical advisory can wait without limit.

P3 · Opus 5.5 LOW

`scripts/check-vulnerabilities.sh:5-6` VERIFIED

THE FIX

Write a response time per severity beside the patching decision, such as seven days for critical.

CVE-06 CI installs and tests the code but writes no list of components and versions.

P3 · Opus 5.5 LOW

After a new advisory, finding which builds carried the package means rebuilding the history by hand.

`.github/workflows/ci.yml:79-95` VERIFIED

THE FIX

Add a CI step that runs syft or a CycloneDX tool over the lockfiles and images and keeps the output as a build artefact.

API and contract design (2): C 0 | H 1 | M 1 | L 0 | I 0 | P 0

Read for what crosses between two pieces, what happens to the other side.

API-01 Controllers cast req.body to a type and services check each field by hand.

P1 · Opus 5.5 HIGH

A missed check on one route lets an unexpected shape, such as an array in place of a string, reach service code.

`src/controllers/authController.ts:64` VERIFIED

THE FIX

Define a schema per form with a library such as zod and parse req.body through it at the top of each handler.

API-02 The web adapter declares its own copy of the image worker reply.

P2 · Opus 5.5 MEDIUM

A change on the worker side would compile and pass the adapter tests, then fail in production.

`src/adapters/imageProcessingAdapter.ts:26-31` VERIFIED

THE FIX

Move the request and reply shapes into one shared module that the worker and the adapter both import, and test the adapter against the real worker routes.

Disaster recovery and durability (4): C 0 | H 0 | M 2 | L 0 | I 0 | P 2

Read for every store, and what its loss costs, whether recovery has ever been tried, losing the thing that proves identity.

DR-01 Restore drills run on demand and their results live in a private repository.

P2 · Opus 5.5 MEDIUM

A reader of this code cannot tell when a restore last worked or how long it took.

`docs/DESIGN_DECISIONS.md:5253` VERIFIED

THE FIX

Schedule scripts/restore-db.sh --drill monthly on the host and write its date, snapshot age and elapsed time to a log the health page reads.

DR-02 Verification refuses any token whose key id differs from the current key.

P2 · Opus 5.5 MEDIUM

A key change after a leak signs out each member at once, and a staged change is impossible.

`src/adapters/jwtSigningAdapter.ts:236` VERIFIED

THE FIX

Hold a short list of accepted key ids with their public keys, sign with the newest, and drop the old one after the session lifetime.

DISASTER RECOVERY AND DURABILITY, CONTINUED

DR-03 A systemd timer runs scripts/backup-db.sh. Opus 5.5 POSITIVE

The script takes a consistent copy with VACUUM INTO and uploads it with bounded retries, and alarms fire on a stale or failing backup.

`scripts/backup-db.sh:147-148` VERIFIED

WORTH KEEPING

The copy relies on VACUUM INTO and on the db_backup_age alarm treating missing data as a breach. Weakening either would let a broken backup go unseen.

DR-04 Each request compares the token's password version with the member's current one, so a password reset signs out stolen sessions at once. Opus 5.5 POSITIVE

`src/middleware/auth.ts:121-123` VERIFIED

WORTH KEEPING

The check depends on bumping password_version at each password change. A path that changes the password without the bump would leave old sessions valid.

Observability and service levels (2): C 0 | H 0 | M 1 | L 0 | I 0 | P 1

Read for the signals that say it is healthy, the failures that page, and the ones that do not, a system that stopped and says nothing.

SLO-01 Error log lines raise a CloudWatch alarm, but nothing groups errors by cause or keeps their stack traces and request context. P2 · Opus 5.5 MEDIUM

Finding the cause of an alarm means searching raw logs.

`terraform/production/cloudwatch.tf:30-40` VERIFIED

THE FIX

Send unhandled errors from the Express error handler and the worker to an error tracking service, or add a CloudWatch Logs Insights query grouping errors by message.

SLO-02 The production metric filter has no default value and the jobs_missed_run alarm uses treat_missing_data = "breaching" over three 300-second periods. Opus 5.5 POSITIVE

When armed, an overdue job or a worker that stopped writing its heartbeat alarms the SNS topic after 15 minutes. Both resources are created only when var.enable_jobs_heartbeat_alarm is true. That variable defaults to false in terraform/production/variables.tf and in terraform.tfvars.example, and the deployed production value is not in the repository. scripts/production-readiness-sitting.sh lists a step that turns it on with scripts/set-terraform-gate.sh.

Continued on page 20

OBSERVABILITY AND SERVICE LEVELS, SLO-02, CONTINUED

SLO-02 The production metric filter has no default value and the jobs_missed_run alarm uses treat_missing_data = "breaching" over three 300-second periods, continued

terraform/production/cloudwatch.tf:609-623 VERIFIED

WORTH KEEPING

Arm enable_jobs_heartbeat_alarm in production once the heartbeat line is flowing, and keep treat_missing_data at breaching and the metric filter without a default value. Until the gate is on, a dead worker raises no alarm from this resource.

Scanner results (19)

Each card is a package or rule the scanners flagged, most severe first, naming any finding above that rests on it.

pillow **106 advisories in versions 10.3.0 and 12.2.0, dependency advisories** CRITICAL

Installed: 10.3.0, the repository's own dependency · 12.2.0, the repository's own dependency

RISK IF LEFT

A crafted input can make the software write outside its memory and let an attacker run code.

An attacker can run operating system commands on the server.

A crafted input can make the software read memory it shouldn't, leaking data or crashing it.

A crafted input can send the code into a loop it never leaves, stalling the service.

A missing value can crash the software.

A crafted input can make the software reserve a huge amount of memory and stop the service.

A crafted request can use enough resources to slow or stop the service.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

The code uses memory after freeing it, so it can crash or let an attacker run code.

A crafted input can make an algorithm run far longer than expected, slowing or stopping the service.

A number can overflow and corrupt memory or get past a size check.

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Bring both copies of pillow, 10.3.0 and 12.2.0, up to 13.0.0 to fix all 106. Upgrade the repository's own copy, 10.3.0. Moving from 10.3.0 to 13.0.0 is a breaking step under semantic versioning, so check the release notes before shipping it. Upgrade the repository's own copy, 12.2.0. Moving from 12.2.0 to 13.0.0 is a breaking step under semantic versioning, so check the release notes before shipping it.

CVE-2026-112393, in 10.3.0, fixed in 13.0.0 CRITICAL

pillow: Heap buffer overflow in _tiffWriteProc when saving TIFF to BytesIO. Pillow is a Python imaging library. From 2.0.0 until 13.0.0, Pillow has a heap buffer overflow and stale-heap disclosure in tiffWriteProc when saving compressed TIFF data through libtiff to a target without a usable fileno(), such as BytesIO.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112393, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in _tiffWriteProc when saving TIFF to BytesIO. Pillow is a Python imaging library. From 2.0.0 until 13.0.0, Pillow has a heap buffer overflow and stale-heap disclosure in tiffWriteProc when saving compressed TIFF data through libtiff to a target without a usable fileno(), such as BytesIO.

CVE-2026-112398, in 10.3.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in FlashPix (FPX) JPEG decoding leads to code execution. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's FlashPix JPEG-tile decoder can write decoded scanlines beyond the allocated tile buffer.

CVE-2026-112398, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in FlashPix (FPX) JPEG decoding leads to code execution. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's FlashPix JPEG-tile decoder can write decoded scanlines beyond the allocated tile buffer.

CVE-2026-112403, in 10.3.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in ImagingJpegDecode. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's JPEG decoder can write a full-width scanline into a buffer sized for a requested draft scale.

CVE-2026-112403, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Heap buffer overflow in ImagingJpegDecode. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's JPEG decoder can write a full-width scanline into a buffer sized for a requested draft scale.

CVE-2026-112900, in 10.3.0, fixed in 13.0.0 — CRITICAL

pillow: Argument Injection in Ghostscript call, potentially leading into RCE. Pillow is a Python imaging library. From 2.6.0 until 13.0.0, Pillow is vulnerable to argument injection when invoking Ghostscript for EPS input.

CVE-2026-112900, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Argument Injection in Ghostscript call, potentially leading into RCE. Pillow is a Python imaging library. From 2.6.0 until 13.0.0, Pillow is vulnerable to argument injection when invoking Ghostscript for EPS input.

CVE-2026-96639, in 12.2.0, fixed in 13.0.0 — CRITICAL

pillow: Pillow multi-frame loaders can reuse stale native image storage after mode transitions. Pillow is a Python imaging library. From 11.0.0 until 13.0.0, multi-frame loaders can retain an ImagingCore allocation created for a narrow frame mode while a later frame of the same dimensions changes the logical mode and decoder tiles to wider RGB or CMYK data.

CVE-2026-112390, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during crafted MIC image parsing. Pillow is a Python imaging library. From 7.2.0 until 13.0.0, Pillow can enter an infinite loop while determining the frame count of a MIC image.

CVE-2026-112390, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during crafted MIC image parsing. Pillow is a Python imaging library. From 7.2.0 until 13.0.0, Pillow can enter an infinite loop while determining the frame count of a MIC image.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112392, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via zero-size images in rank filters. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's rank-based filters can dereference invalid image storage for a zero-size image.

CVE-2026-112392, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via zero-size images in rank filters. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's rank-based filters can dereference invalid image storage for a zero-size image.

CVE-2026-112397, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via out-of-bounds memory access on zero-width images. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's ImageMorph.MorphOp.apply() can access memory before a row buffer for a zero-width image. PPM and PGM input can create an image with width zero, and the native morphology routine indexes outrow[width - 1] without rejecting that geometry.

CVE-2026-112397, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via out-of-bounds memory access on zero-width images. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's ImageMorph.MorphOp.apply() can access memory before a row buffer for a zero-width image. PPM and PGM input can create an image with width zero, and the native morphology routine indexes outrow[width - 1] without rejecting that geometry.

CVE-2026-112399, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of service via crafted APNG image. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow can allocate an APNG disposal background at the full canvas size before applying the decompression-bomb check.

CVE-2026-112399, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of service via crafted APNG image. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow can allocate an APNG disposal background at the full canvas size before applying the decompression-bomb check.

CVE-2026-112400, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via memory exhaustion from crafted GIF image. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow can retain a rejected GIF frame size after a decompression-bomb exception.

CVE-2026-112400, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via memory exhaustion from crafted GIF image. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow can retain a rejected GIF frame size after a decompression-bomb exception.

CVE-2026-112402, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of service via double free during image transformation. Pillow is a Python imaging library. Prior to 13.0.0, Pillow can double free image memory when ImagingScaleAffine encounters a selective allocation failure. The affected fast path handles Transform.EXTENT or pure scale-and-translate Transform.AFFINE operations with the default NEAREST resampling.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112402, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via double free during image transformation. Pillow is a Python imaging library. Prior to 13.0.0, Pillow can double free image memory when ImagingScaleAffine encounters a selective allocation failure. The affected fast path handles Transform.EXTENT or pure scale-and-translate Transform.AFFINE operations with the default NEAREST resampling.

CVE-2026-112404, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF decoding. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow's TIFF tile and RGBA decode paths can read beyond row data produced by libtiff.

CVE-2026-112404, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF decoding. Pillow is a Python imaging library. From 8.1.0 until 13.0.0, Pillow's TIFF tile and RGBA decode paths can read beyond row data produced by libtiff.

CVE-2026-112405, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via null pointer dereference in Image.merge(). Pillow is a Python imaging library. From 12.0.0 until 13.0.0, Pillow's Image.merge() can dereference a null image8 plane. Validation skips the first input band, allowing a 32-bit integer or floating-point image backed by image32 storage to be merged as a narrower multiband image.

CVE-2026-112406, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during PDF page rewriting. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can enter an infinite loop while rewriting PDF pages. PdfParser.rewritepages() follows Parent relationships without detecting a cycle in the page tree.

CVE-2026-112406, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via infinite loop during PDF page rewriting. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can enter an infinite loop while rewriting PDF pages. PdfParser.rewritepages() follows Parent relationships without detecting a cycle in the page tree.

CVE-2026-112892, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via unbounded memory expansion in MSP image decoder. Pillow is a Python imaging library. From 4.1.0 until 13.0.0, Pillow's MSP RLE decoder can expand a small file into an unbounded in-memory buffer. The decoder writes run-length output to BytesIO without limiting expansion to the declared image size.

CVE-2026-112892, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via unbounded memory expansion in MSP image decoder. Pillow is a Python imaging library. From 4.1.0 until 13.0.0, Pillow's MSP RLE decoder can expand a small file into an unbounded in-memory buffer. The decoder writes run-length output to BytesIO without limiting expansion to the declared image size.

CVE-2026-112893, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via invalid pointer free during font rendering. Pillow is a Python imaging library. From 10.0.0 until 13.0.0, Pillow can free an invalid glyph pointer during FreeType rendering with an active stroker. If FTLoadGlyph fails, cleanup may call FTDoneGlyph on an uninitialized or stale glyph variable.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112893, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via invalid pointer free during font rendering. Pillow is a Python imaging library. From 10.0.0 until 13.0.0, Pillow can free an invalid glyph pointer during FreeType rendering with an active stroker. If FTLoadGlyph fails, cleanup may call FTDoneGlyph on an uninitialized or stale glyph variable.

CVE-2026-112894, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via crafted multi-frame image conversion. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow takes quadratic time to reserve PDF object identifiers when saving many frames with saveall enabled. PdfParser.nextobjectid() repeatedly rebuilds and scans all previously reserved identifiers for every object.

CVE-2026-112894, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via crafted multi-frame image conversion. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow takes quadratic time to reserve PDF object identifiers when saving many frames with saveall enabled. PdfParser.nextobjectid() repeatedly rebuilds and scans all previously reserved identifiers for every object.

CVE-2026-112895, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted PDF during append operations. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can exhaust resources while parsing an existing PDF during an append operation.

CVE-2026-112895, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of service via crafted PDF during append operations. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow can exhaust resources while parsing an existing PDF during an append operation.

CVE-2026-112896, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF encoder. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's TIFF encoder can read beyond a ColorMap buffer when retained TIFF metadata has a plane size inconsistent with BitsPerSample. A small TIFF can be opened normally and then retain a crafted ColorMap that is reused when the image is saved.

CVE-2026-112896, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Denial of Service via out-of-bounds read in TIFF encoder. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's TIFF encoder can read beyond a ColorMap buffer when retained TIFF metadata has a plane size inconsistent with BitsPerSample. A small TIFF can be opened normally and then retain a crafted ColorMap that is reused when the image is saved.

CVE-2026-112897, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Information disclosure via uninitialized buffer in TIFF decoding. Pillow is a Python imaging library. From 5.3.0 until 13.0.0, Pillow can return uninitialized memory as pixels when libtiff performs a short decode of JPEG-compressed or Group 4 fax TIFF data.

CVE-2026-112897, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Information disclosure via uninitialized buffer in TIFF decoding. Pillow is a Python imaging library. From 5.3.0 until 13.0.0, Pillow can return uninitialized memory as pixels when libtiff performs a short decode of JPEG-compressed or Group 4 fax TIFF data.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112902, in 10.3.0, fixed in 13.0.0 — HIGH

Pillow: Memory disclosure and segfault in libtiff encoder via crafted TIFF tags. Pillow is a Python imaging library. In versions through 12.3.0, the libtiff TIFF encoder can pass arguments to TIFFSetField() that do not match libtiff's definition of the corresponding tag.

CVE-2026-112902, in 12.2.0, fixed in 13.0.0 — HIGH

Pillow: Memory disclosure and segfault in libtiff encoder via crafted TIFF tags. Pillow is a Python imaging library. In versions through 12.3.0, the libtiff TIFF encoder can pass arguments to TIFFSetField() that do not match libtiff's definition of the corresponding tag.

CVE-2026-25990, in 10.3.0, fixed in 12.1.1 — HIGH

pillow: Out-of-bounds Write via Specially Crafted PSD Image. Pillow is a Python imaging library. From 10.3.0 to before 12.1.1, an out-of-bounds write may be triggered when loading a specially crafted PSD image. This vulnerability is fixed in 12.1.1.

CVE-2026-40192, in 10.3.0, fixed in 12.2.0 — HIGH

Pillow: Denial of Service via decompression bomb in FITS image processing. Pillow is a Python imaging library. Versions 10.3.0 through 12.1.1 did not limit the amount of GZIP-compressed data read when decoding a FITS image, making them vulnerable to decompression bomb attacks.

CVE-2026-42311, in 10.3.0, fixed in 12.2.0 — HIGH

Pillow: python-pillow: Pillow: Arbitrary code execution via malicious PSD file processing. Pillow is a Python imaging library. From version 10.3.0 to before version 12.2.0, processing a malicious PSD file could lead to memory corruption, potentially resulting in a crash or arbitrary code execution. This issue has been patched in version 12.2.0.

CVE-2026-54058, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Memory disclosure or denial of service via crafted McIdas AREA image. Pillow is a Python imaging library. Prior to 12.3.0, when Pillow loads an uncompressed McIdas AREA image from a filename through the mmap raw codec path, attacker-controlled header words can set a row stride smaller than the natural row width, causing pixel access such as Image.tobytes(), getpixel,...

CVE-2026-54058, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Memory disclosure or denial of service via crafted McIdas AREA image. Pillow is a Python imaging library. Prior to 12.3.0, when Pillow loads an uncompressed McIdas AREA image from a filename through the mmap raw codec path, attacker-controlled header words can set a row stride smaller than the natural row width, causing pixel access such as Image.tobytes(), getpixel,...

CVE-2026-54059, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted PCF font data. Pillow is a Python imaging library. Prior to 12.3.0, PIL/PcfFontFile.py loadbitmaps() read glyph dimensions from the PCF METRICS section and passed them directly to Image.frombytes() without calling Image.decompressionbombcheck(), allowing crafted PCF font data to cause excessive memory allocation.

CVE-2026-54059, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted PCF font data. Pillow is a Python imaging library. Prior to 12.3.0, PIL/PcfFontFile.py loadbitmaps() read glyph dimensions from the PCF METRICS section and passed them directly to Image.frombytes() without calling Image.decompressionbombcheck(), allowing crafted PCF font data to cause excessive memory allocation.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-54060, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via excessive memory allocation when processing font files. Pillow is a Python imaging library. Prior to 12.3.0, PIL/FontFile.py FontFile.compile() assembled per-glyph images into a combined bitmap with Image.new("1", (xsize, ysize)) without calling Image.decompressionbombcheck(), allowing a font to trigger excessive allocation during conversion or saving.

CVE-2026-54060, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via excessive memory allocation when processing font files. Pillow is a Python imaging library. Prior to 12.3.0, PIL/FontFile.py FontFile.compile() assembled per-glyph images into a combined bitmap with Image.new("1", (xsize, ysize)) without calling Image.decompressionbombcheck(), allowing a font to trigger excessive allocation during conversion or saving.

CVE-2026-55379, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted BDF font file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/BdfFontFile.py bdfchar() read the BBX width and height field from a BDF font file and passed attacker-controlled dimensions to Image.new() without calling Image.decompressionbombcheck(), bypassing Pillow's documented decompression bomb...

CVE-2026-55379, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted BDF font file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/BdfFontFile.py bdfchar() read the BBX width and height field from a BDF font file and passed attacker-controlled dimensions to Image.new() without calling Image.decompressionbombcheck(), bypassing Pillow's documented decompression bomb...

CVE-2026-55380, in 10.3.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted GD 2.x image file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/GdImageFile.py GdImageFile.open() read image dimensions from the GD 2.x header and stored them in self.size without calling Image.decompressionbombcheck(), allowing a crafted .gd file to trigger excessive C-heap allocation when loaded.

CVE-2026-55380, in 12.2.0, fixed in 12.3.0 — HIGH

python-pillow: Pillow: Denial of Service via crafted GD 2.x image file. Pillow is a Python imaging library. Prior to 12.3.0, PIL/GdImageFile.py GdImageFile.open() read image dimensions from the GD 2.x header and stored them in self.size without calling Image.decompressionbombcheck(), allowing a crafted .gd file to trigger excessive C-heap allocation when loaded.

CVE-2026-59197, in 10.3.0, fixed in 12.3.0 — HIGH

Pillow: Native heap out-of-bounds write. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's public rank-filter API can trigger a native heap out-of-bounds write when given a very large odd filter size because ImageFilter.RankFilter.filter() calls image.expand(size // 2, size // 2) before rank-filter size validation and...

CVE-2026-59197, in 12.2.0, fixed in 12.3.0 — HIGH

Pillow: Native heap out-of-bounds write. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's public rank-filter API can trigger a native heap out-of-bounds write when given a very large odd filter size because ImageFilter.RankFilter.filter() calls image.expand(size // 2, size // 2) before rank-filter size validation and...

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-59199, in 10.3.0, fixed in 12.3.0 HIGH

Pillow: Denial of Service via out-of-bounds write in image processing. Pillow is a Python imaging library. Prior to 12.3.0, Pillow public image coordinate APIs can trigger a native heap out-of-bounds write when given coordinates near the signed 32-bit integer limits in Image.paste(), Image.crop(), or Image.alphacomposite(). This issue is fixed in version 12.3.0.

CVE-2026-59199, in 12.2.0, fixed in 12.3.0 HIGH

Pillow: Denial of Service via out-of-bounds write in image processing. Pillow is a Python imaging library. Prior to 12.3.0, Pillow public image coordinate APIs can trigger a native heap out-of-bounds write when given coordinates near the signed 32-bit integer limits in Image.paste(), Image.crop(), or Image.alphacomposite(). This issue is fixed in version 12.3.0.

CVE-2026-59200, in 10.3.0, fixed in 12.3.0 HIGH

Pillow: Denial of service via crafted PDF stream. Pillow is a Python imaging library. From 5.1.0 until 12.3.0, PdfParser.PdfStream.decode() in PIL/PdfParser.py calls zlib.decompress() with bufsize set to the PDF stream Length field without bounding the decompressed output size, allowing a crafted FlateDecode PDF stream to exhaust memory from a...

CVE-2026-59200, in 12.2.0, fixed in 12.3.0 HIGH

Pillow: Denial of service via crafted PDF stream. Pillow is a Python imaging library. From 5.1.0 until 12.3.0, PdfParser.PdfStream.decode() in PIL/PdfParser.py calls zlib.decompress() with bufsize set to the PDF stream Length field without bounding the decompressed output size, allowing a crafted FlateDecode PDF stream to exhaust memory from a...

CVE-2026-59204, in 10.3.0, fixed in 12.3.0 HIGH

Pillow: Denial of Service via crafted JPEG2000 image. Pillow is a Python imaging library. From 8.2.0 through 12.2.0, src/libImaging/Jpeg2KDecode.c accumulates totalcomponentwidth across every tile in a JPEG2000 image instead of recomputing it per tile, allowing a crafted tiled JPEG2000 file to force substantially higher transient memory usage and...

CVE-2026-59204, in 12.2.0, fixed in 12.3.0 HIGH

Pillow: Denial of Service via crafted JPEG2000 image. Pillow is a Python imaging library. From 8.2.0 through 12.2.0, src/libImaging/Jpeg2KDecode.c accumulates totalcomponentwidth across every tile in a JPEG2000 image instead of recomputing it per tile, allowing a crafted tiled JPEG2000 file to force substantially higher transient memory usage and...

CVE-2026-59205, in 10.3.0, fixed in 12.3.0 HIGH

Pillow: Controlled native heap corruption in ImageCms.ImageCmsTransform.apply API. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's ImageCms.ImageCmsTransform.apply(im, imOut) API can trigger controlled native heap corruption when the caller supplies an output image whose mode does not match the transform's declared output mode. This issue is fixed in version 12.3.0.

CVE-2026-59205, in 12.2.0, fixed in 12.3.0 HIGH

Pillow: Controlled native heap corruption in ImageCms.ImageCmsTransform.apply API. Pillow is a Python imaging library. Prior to 12.3.0, Pillow's ImageCms.ImageCmsTransform.apply(im, imOut) API can trigger controlled native heap corruption when the caller supplies an output image whose mode does not match the transform's declared output mode. This issue is fixed in version 12.3.0.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-96637, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via decompression bomb bypass in SPIDER images. Pillow is a Python imaging library. Prior to 13.0.0, SpiderImageFile.seek() in src/PIL/SpiderImagePlugin.py reparses a later SPIDER stack frame and replaces self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96637, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via decompression bomb bypass in SPIDER images. Pillow is a Python imaging library. Prior to 13.0.0, SpiderImageFile.seek() in src/PIL/SpiderImagePlugin.py reparses a later SPIDER stack frame and replaces self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96640, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via duplicate page references in PDF files. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, PdfParser.linearizepagetree() in src/PIL/PdfParser.py treats a PDF /Pages graph as a tree without tracking duplicate indirect references.

CVE-2026-96640, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via duplicate page references in PDF files. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, PdfParser.linearizepagetree() in src/PIL/PdfParser.py treats a PDF /Pages graph as a tree without tracking duplicate indirect references.

CVE-2026-96642, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via negative archive member size in TarIO. Pillow is a Python imaging library. Prior to 13.0.0, the TarIO initializer in src/PIL/TarIO.py accepts a negative octal member size and computes a backward seek that returns to the same 512-byte header.

CVE-2026-96642, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via negative archive member size in TarIO. Pillow is a Python imaging library. Prior to 13.0.0, the TarIO initializer in src/PIL/TarIO.py accepts a negative octal member size and computes a backward seek that returns to the same 512-byte header.

CVE-2026-96643, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via repeated EXIF headers. Pillow is a Python imaging library. From 11.0.0 until 13.0.0, Exif.load() in src/PIL/Image.py repeatedly slices the remaining EXIF data while it begins with the six-byte Exif header.

CVE-2026-96644, in 10.3.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via out-of-bounds read in metafile parser. Pillow is a Python imaging library. Prior to 13.0.0 on Windows, src/PIL/WmfImagePlugin.py passes unchecked 32-bit WMF or EMF dimensions to the native drawwmf handler in src/display.c.

CVE-2026-96644, in 12.2.0, fixed in 13.0.0 HIGH

pillow: Denial of Service via out-of-bounds read in metafile parser. Pillow is a Python imaging library. Prior to 13.0.0 on Windows, src/PIL/WmfImagePlugin.py passes unchecked 32-bit WMF or EMF dimensions to the native drawwmf handler in src/display.c.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-96778, in 10.3.0, fixed in 13.0.0 — HIGH

pillow: Arbitrary code execution via JPEG encoder buffer overflow. Pillow is a Python imaging library. From 9.4.0 until 13.0.0, ImagingJpegEncode() in src/libImaging/JpegEncode.c can call jpegwritemarker() for a JPEG COM comment when an ICC profile has exactly filled the 65536-byte encoder buffer.

CVE-2026-96778, in 12.2.0, fixed in 13.0.0 — HIGH

pillow: Arbitrary code execution via JPEG encoder buffer overflow. Pillow is a Python imaging library. From 9.4.0 until 13.0.0, ImagingJpegEncode() in src/libImaging/JpegEncode.c can call jpegwritemarker() for a JPEG COM comment when an ICC profile has exactly filled the 65536-byte encoder buffer.

GHSA-78g4-xqwv-q3g8, in 12.2.0, fixed in 13.0.0 — HIGH

Pillow: Bundled libopenjp2 2.5.4 in all wheels since 11.1.0 carries OSV-2025-219 heap-buffer-overflow write reachable from Image.open().load(). Every Pillow wheel from 11.1.0 onward bundles a libopenjp2 containing a heap-buffer-overflow write that is fixed upstream on master but has never appeared in an OpenJPEG release. See https://osv.dev/vulnerability/OSV-2025-219 Because the wheel bundles its own copy, a patched host OS does not help.

CVE-2026-112391, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via unbounded recursion in PDF parser. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow's PdfParser.getvalue() can recurse without a limit while reading nested PDF objects. The parser follows attacker-controlled arrays and dictionaries when an existing PDF is opened for append.

CVE-2026-112391, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via unbounded recursion in PDF parser. Pillow is a Python imaging library. From 5.1.0 until 13.0.0, Pillow's PdfParser.getvalue() can recurse without a limit while reading nested PDF objects. The parser follows attacker-controlled arrays and dictionaries when an existing PDF is opened for append.

CVE-2026-112394, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via out-of-bounds read in raw decoders. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's P;2L and P;4L raw decoders can read past the end of an input buffer. ImagingRawDecode calculates a packed-pixel row size, while the unpackers read separately padded bit planes.

CVE-2026-112394, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via out-of-bounds read in raw decoders. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's P;2L and P;4L raw decoders can read past the end of an input buffer. ImagingRawDecode calculates a packed-pixel row size, while the unpackers read separately padded bit planes.

CVE-2026-112395, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via crafted tiled TIFF image. Pillow is a Python imaging library. From 8.2.0 until 13.0.0, Pillow's tiled-TIFF decoder can read past the tile buffer while copying four-byte pixels.

CVE-2026-112395, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via crafted tiled TIFF image. Pillow is a Python imaging library. From 8.2.0 until 13.0.0, Pillow's tiled-TIFF decoder can read past the tile buffer while copying four-byte pixels.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112396, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: arbitrary code execution via heap use-after-free during TIFF encoding. Pillow is a Python imaging library. From 11.3.0 until 13.0.0, Pillow has a heap use-after-free when libtiff rejects a tag while encoding TIFF data to an in-memory buffer.

CVE-2026-112401, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted GIF comments. Pillow is a Python imaging library. From 5.4.0 until 13.0.0, Pillow performs quadratic copying while parsing GIF comments. GifImageFile.seek() repeatedly appends immutable bytes for comment sub-blocks and multiple comment extensions, and frame zero is parsed during Image.open().

CVE-2026-112401, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted GIF comments. Pillow is a Python imaging library. From 5.4.0 until 13.0.0, Pillow performs quadratic copying while parsing GIF comments. GifImageFile.seek() repeatedly appends immutable bytes for comment sub-blocks and multiple comment extensions, and frame zero is parsed during Image.open().

CVE-2026-112891, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via large GIF comments. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow performs quadratic copying when saving a GIF with a long comment. getglobalheader() repeatedly copies portions of comment data while assembling the global header, including comments retained from an untrusted input image.

CVE-2026-112891, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via large GIF comments. Pillow is a Python imaging library. From 9.2.0 until 13.0.0, Pillow performs quadratic copying when saving a GIF with a long comment. getglobalheader() repeatedly copies portions of comment data while assembling the global header, including comments retained from an untrusted input image.

CVE-2026-112898, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via empty palette quantization. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, Pillow can disclose uninitialized stack memory when Image.quantize() uses an empty palette.

CVE-2026-112898, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via empty palette quantization. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, Pillow can disclose uninitialized stack memory when Image.quantize() uses an empty palette.

CVE-2026-112899, in 10.3.0, fixed in 13.0.0 — MEDIUM

Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, . Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, EPS rendering does not validate the scaled image dimensions before invoking Ghostscript.

CVE-2026-112899, in 12.2.0, fixed in 13.0.0 — MEDIUM

Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, . Pillow is a Python imaging library. In versions 2.3.0 through 12.3.0, EPS rendering does not validate the scaled image dimensions before invoking Ghostscript.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-112901, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted XBM image header. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's XBM header parser is vulnerable to regular-expression denial of service.

CVE-2026-112901, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted XBM image header. Pillow is a Python imaging library. Prior to 13.0.0, Pillow's XBM header parser is vulnerable to regular-expression denial of service.

CVE-2026-114501, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Information disclosure via improper memory alignment during Arrow export. Pillow is a Python imaging library. From 11.2.1 until 13.0.0, Arrow export assumes that an image's rows are tightly contiguous and exports from im->blocks[0].ptr even when PILLOWALIGNMENT makes alignedlinesize include row padding or an aligned offset before the first row.

CVE-2026-42308, in 10.3.0, fixed in 12.2.0 — MEDIUM

Pillow: Denial of Service via integer overflow in font processing. Pillow is a Python imaging library. Prior to version 12.2.0, if a font advances for each glyph by an exceeding large amount, when Pillow keeps track of the current position, it may lead to an integer overflow. This issue has been patched in version 12.2.0.

CVE-2026-42310, in 10.3.0, fixed in 12.2.0 — MEDIUM

Pillow: Denial of Service via malicious PDF processing. Pillow is a Python imaging library. From version 4.2.0 to before version 12.2.0, an attacker can supply a malicious PDF that causes the process to hang indefinitely, consuming 100% CPU and making the application unresponsive. This issue has been patched in version 12.2.0.

CVE-2026-55798, in 10.3.0, fixed in 12.3.0 — MEDIUM

python-pillow: Pillow: Arbitrary command injection via shell metacharacters in file paths. Pillow is a Python imaging library. Prior to 12.3.0, WindowsViewer.getcommand() constructed a cmd.exe shell command by directly embedding a file path into an f-string without escaping and passed the result to subprocess.Popen(..., shell=True), allowing shell metacharacters in the file path to...

CVE-2026-55798, in 12.2.0, fixed in 12.3.0 — MEDIUM

python-pillow: Pillow: Arbitrary command injection via shell metacharacters in file paths. Pillow is a Python imaging library. Prior to 12.3.0, WindowsViewer.getcommand() constructed a cmd.exe shell command by directly embedding a file path into an f-string without escaping and passed the result to subprocess.Popen(..., shell=True), allowing shell metacharacters in the file path to...

CVE-2026-59198, in 10.3.0, fixed in 12.3.0 — MEDIUM

Pillow: Information disclosure via TGA RLE encoder out-of-bounds read. Pillow is a Python imaging library. From 5.2.0 until 12.3.0, Pillow's TGA RLE encoder reads past its packed row buffer when saving a mode 1 image with TGA RLE compression, allowing adjacent process heap bytes to be copied into the generated TGA file. This issue is fixed in version 12.3.0.

CVE-2026-59198, in 12.2.0, fixed in 12.3.0 — MEDIUM

Pillow: Information disclosure via TGA RLE encoder out-of-bounds read. Pillow is a Python imaging library. From 5.2.0 until 12.3.0, Pillow's TGA RLE encoder reads past its packed row buffer when saving a mode 1 image with TGA RLE compression, allowing adjacent process heap bytes to be copied into the generated TGA file. This issue is fixed in version 12.3.0.

SCANNER RESULTS, PILLOW, CONTINUED

CVE-2026-59203, in 12.2.0, fixed in 12.3.0 — MEDIUM

Pillow: Denial of Service via crafted EPS file. Pillow is a Python imaging library. From 12.0.0 through 12.2.0, Pillow's EPS parser in PIL/EpsImagePlugin.py accepts a negative byte count in the %%BeginBinary directive, allowing a crafted EPS file to cause Image.open() to seek backwards to the same directive and parse it repeatedly in an infinite...

CVE-2026-96636, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via decompression bomb check bypass in multi-frame images. Pillow is a Python imaging library. Prior to 13.0.0, MpoImageFile.seek() and DcxImageFile.seek() reparse later MPO or DCX frames and replace self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96636, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via decompression bomb check bypass in multi-frame images. Pillow is a Python imaging library. Prior to 13.0.0, MpoImageFile.seek() and DcxImageFile.seek() reparse later MPO or DCX frames and replace self.size without rerunning Image.decompressionbombcheck().

CVE-2026-96638, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted RLE BMP image. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, BmpRleDecoder.decode() in src/PIL/BmpImagePlugin.py permits crafted RLE BMP delta escapes and absolute-mode runs to append beyond the remaining destlength without a per-branch cap.

CVE-2026-96638, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via crafted RLE BMP image. Pillow is a Python imaging library. From 9.1.0 until 13.0.0, BmpRleDecoder.decode() in src/PIL/BmpImagePlugin.py permits crafted RLE BMP delta escapes and absolute-mode runs to append beyond the remaining destlength without a per-branch cap.

CVE-2026-96641, in 10.3.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via integer overflow in text-width calculation. Pillow is a Python imaging library. Prior to 13.0.0, PILfont text-width accumulation in src/imaging.c checks positive glyph advances against INTMAX but does not check negative advances against INTMIN.

CVE-2026-96641, in 12.2.0, fixed in 13.0.0 — MEDIUM

pillow: Denial of Service via integer overflow in text-width calculation. Pillow is a Python imaging library. Prior to 13.0.0, PILfont text-width accumulation in src/imaging.c checks positive glyph advances against INTMAX but does not check negative advances against INTMIN.

handlebars **3 advisories in 4.7.9, dependency advisories** — Cited in CVE-02 — CRITICAL

Installed: 4.7.9, brought in by express-handlebars 8.0.6

Continued on page 33

SCANNER RESULTS, HANDLEBARS, CONTINUED

handlebars 3 advisories in 4.7.9, dependency advisories, continued

RISK IF LEFT

A deny list misses a dangerous value, so it gets through the check meant to stop it.

The code doesn't handle an unusual input that looks valid, so a crafted value can crash the software or get past a check.

An attacker can make the application run code of their choosing.

The code doesn't escape output for where it lands, so crafted input can change what a browser or parser does.

THE FIX

Version 4.7.10 fixes all 3. handlebars 4.7.9 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses handlebars 4.7.10 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "handlebars": "^4.7.10" } }.

CVE-2026-106445, fixed in 4.7.10 — CRITICAL

handlebars: JavaScript Injection via Own Property Check Bypass. Handlebars provides the power necessary to let users build semantic templates. From 3.0.0 until 4.7.10, Handlebars lookupProperty returns Function.prototype.constructor before applying the prototype-access deny list because constructor is an own property of Function.prototype.

CVE-2026-106446, fixed in 4.7.10 — CRITICAL

handlebars: JavaScript Injection via AST Type Confusion in compile (Program.blockParams). Handlebars provides the power necessary to let users build semantic templates. From 4.0.0 until 4.7.10, Handlebars.compile() and Handlebars.precompile() accept pre-parsed AST objects while validating only selected PathExpression, NumberLiteral, and BooleanLiteral values.

CVE-2026-106444, fixed in 4.7.10 — MEDIUM

handlebars: Cross-Site Scripting via unescaped closing script tags in precompiled templates. Handlebars provides the power necessary to let users build semantic templates. From 4.0.0 until 4.7.10, Handlebars.precompile() uses quotedString() in lib/handlebars/compiler/code-gen.js to emit static template text into generated JavaScript without escaping sequences that terminate an enclosing...

certifi 1 advisory in 2026.2.25, dependency advisories — Cited in CVE-01 — CRITICAL

Installed: 2026.2.25, the repository's own dependency

THE FIX

Upgrade certifi from 2026.2.25 to 2026.10.18 to fix it.

GHSA-6q48-6c7w-9gw2, fixed in 2026.10.18 — CRITICAL

certifi bundles emSign root CAs with compromised intermediate CA keys. Certifi versions before 2026.10.18 include the emSign ECC Root CA - G3 root certificate in their bundled CA store. Eight eMudhra intermediate CA certificates that chain to this root have compromised private keys and the CA has revoked them.

SCANNER RESULTS, CONTINUED

proxy-addr 1 advisory in 2.0.7, dependency advisories

CRITICAL

Installed: 2.0.7, brought in by express 4.22.2

THE FIX

Version 2.0.8 fixes it. proxy-addr 2.0.7 comes in through express 4.22.2. Upgrade it to a release that uses proxy-addr 2.0.8 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "proxy-addr": "^2.0.8" } }.

CVE-2026-90711, fixed in 2.0.8 — CRITICAL

proxy-addr: proxy-addr vulnerable to IP spoofing via IPv4-mapped IPv6 trust subnet. proxy-addr is a Node.js module that determines a request's client address behind trusted reverse proxies, and it backs Express req.ip and req.ips.

urllib3 5 advisories in 2.6.3, dependency advisories

HIGH

Installed: 2.6.3, the repository's own dependency

RISK IF LEFT

Someone without permission can see information meant to stay private.

The code doesn't check a certificate properly, so someone can intercept or alter the traffic.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

A crafted input can send the code into a loop it never leaves, stalling the service.

THE FIX

Upgrade urllib3 from 2.6.3 to 2.8.0 to fix all 5.

CVE-2026-44431, fixed in 2.7.0 — HIGH

urllib3: Information disclosure via cross-origin redirects forwarding sensitive headers. urllib3 is an HTTP client library for Python. From 1.23 to before 2.7.0, cross-origin redirects followed from the low-level API via ProxyManager.connectionfromurl().urlopen(..., assertsamehost=False) still forward these sensitive headers. This vulnerability is fixed in 2.7.0.

CVE-2026-44432, fixed in 2.7.0 — HIGH

urllib3: Denial of Service due to excessive HTTP response decompression. urllib3 is an HTTP client library for Python. From 2.6.0 to before 2.7.0, urllib3 could decompress the whole response instead of the requested portion (1) during the second HTTPResponse.read(amt=N) call when the response was decompressed using the official Brotli library or (2) when...

CVE-2026-97687, fixed in 2.8.0 — HIGH

urllib3: Traffic interception via HTTPS proxy TLS configuration override. urllib3 is an HTTP client library for Python. From 1.26.0 until 2.8.0, the proxysslcontext, proxyasserthostname, proxyassertfingerprint, sslcontext, certreqs, verifymode, useforwardingforhttps=True, and CERTNONE configuration paths fail to remain separated because target-server TLS settings are...

SCANNER RESULTS, URLLIB3, CONTINUED

CVE-2026-97689, fixed in 2.8.0 — HIGH

urllib3: Denial of Service via unbounded memory allocation in chunk parser. urllib3 is an HTTP client library for Python. From 1.10.3 until 2.8.0, the HTTPResponse.readchunked and HTTPResponse.stream methods can allocate unbounded memory because the streaming chunk parser buffers the chunk-size field until newline or EOF without a length bound.

CVE-2026-97688, fixed in 2.8.0 — MEDIUM

urllib3: Denial of Service via infinite loop during chunked Deflate decoding. urllib3 is an HTTP client library for Python. From 2.6.2 until 2.8.0, HTTPResponse.stream and HTTPResponse.readchunked can enter an infinite loop because the Deflate decoder retains trailing bytes as unconsumed input after reaching end-of-stream and repeatedly decodes them without progress.

soupsieve 4 advisories in 2.8.3, dependency advisories — HIGH

Installed: 2.8.3, the repository's own dependency

RISK IF LEFT

A crafted request can use enough resources to slow or stop the service.

Nothing limits how much a request can allocate, so a crafted one can exhaust memory and stop the service.

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Upgrade soupsieve from 2.8.3 to 2.9.0 to fix all 4.

CVE-2026-49476, fixed in 2.8.4, in 2 lockfiles — HIGH

python-soupsieve: Soupsieve: Denial of Service via crafted CSS selector string. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.8.4, the CSS selector parser in soupsieve allocates unbounded memory when compiling large comma-separated selector lists, allowing an attacker who can supply a crafted selector string to soupsieve.compile()...

CVE-2026-49477, fixed in 2.8.4, in 2 lockfiles — HIGH

soupsieve: Denial of Service via crafted CSS selector strings. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.8.4, the CSS selector parser in soupsieve contains a regular expression vulnerable to catastrophic backtracking when processing an attribute selector with an unterminated quoted value in...

CVE-2026-85999, fixed in 2.9.0, in 2 lockfiles — MEDIUM

soupsieve: Soup Sieve: Denial of Service via crafted CSS selectors. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, selectoriter in src/soupsieve/cssparser.py trims the raw selector with REWSEND, an end-anchored WSC whitespace-and-comment expression used with search(), so the regular expression engine retries a greedy...

CVE-2026-86000, fixed in 2.9.0, in 2 lockfiles — MEDIUM

soupsieve: Soup Sieve: Denial of Service via crafted CSS selectors. Soup Sieve is a CSS selector library designed to be used with Beautiful Soup 4. Prior to 2.9, the selector parser in src/soupsieve/cssparser.py defines IDENTIFIER with adjacent quantified groups over overlapping character classes, and VALUE embeds IDENTIFIER for attribute selectors.

SCANNER RESULTS, CONTINUED

body-parser 1 advisory in 1.20.6, dependency advisories

HIGH

Installed: 1.20.6, brought in by express 4.22.2

RISK IF LEFT

The code doesn't catch an unexpected error, so a crafted request can crash the service.

THE FIX

Version 1.20.9 fixes it. body-parser 1.20.6 comes in through express 4.22.2. Upgrade it to a release that uses body-parser 1.20.9 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "body-parser": "^1.20.9" } }.

CVE-2026-111181, fixed in 2.4.0, 1.20.9 HIGH

body-parser: Denial of Service via unhandled decompression stream error. body-parser is body parsing middleware for Node.js and Express. In versions before 1.20.9 and in versions from 2.0.0 before 2.4.0, a single request can crash any application using body-parser with default options.

sharp 1 advisory in 0.35.4, dependency advisories

HIGH

Installed: 0.35.4, the repository's own dependency

THE FIX

Upgrade sharp from 0.35.4 to 0.35.5 to fix it.

GHSA-wq5f-xc86-pv6w, fixed in 0.35.5 HIGH

sharp : Vulnerability in librsvg dependency CVE-2026-96889. A memory-related vulnerability has been discovered and fixed in the upstream librsvg dependency. When certain runtime-specific conditions apply, this vulnerability can lead to possible remote code execution (RCE) on glibc-based Linux. Most people rely on the prebuilt binaries provided by sharp.

var-in-href 426 places, static analysis

MEDIUM

Detected a template variable used in an anchor tag with the 'href' attribute. This allows a malicious actor to input the 'javascript:' URI and is subject to cross- site scripting (XSS) attacks. If using Flask, use 'url_for()' to safely generate a URL. If using Django, use the 'url' filter to safely generate a URL. If using Mustache, use a URL encoding library, or prepend a slash '/' to the variable for relative links (`href="/{{link}}"`). You may also consider setting the Content Security Policy (CSP) header.

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 426 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/admin-roles/grant-confirm.hbs:26

src/views/admin/admin-roles/index.hbs:21

src/views/admin/admin-roles/revoke-confirm.hbs:22

src/views/admin/alarms/index.hbs:64

src/views/admin/alarms/index.hbs:65

src/views/admin/audit-log/index.hbs:45

src/views/admin/audit-log/index.hbs:49

src/views/admin/audit-log/index.hbs:56

src/views/admin/audit-log/index.hbs:57

src/views/admin/audit-log/index.hbs:65

src/views/admin/audit-log/index.hbs:66

src/views/admin/audit-log/summary.hbs:11

src/views/admin/broadcasts/detail.hbs:27

src/views/admin/broadcasts/index.hbs:24

src/views/admin/broadcasts/index.hbs:33

src/views/admin/broadcasts/index.hbs:34

src/views/admin/club-leadership/demote-confirm.hbs:13

src/views/admin/club-leadership/demote-confirm.hbs:26

src/views/admin/club-leadership/detail.hbs:66

src/views/admin/clubs/confirm.hbs:36

src/views/admin/clubs/index.hbs:30

src/views/admin/clubs/record.hbs:103

src/views/admin/clubs/record.hbs:108

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/clubs/record.hbs:17

src/views/admin/clubs/record.hbs:18

src/views/admin/clubs/record.hbs:36

src/views/admin/consecutive-record-delete-confirm.hbs:25

src/views/admin/consecutive-record-edit.hbs:81

src/views/admin/consecutive-record-edit.hbs:84

src/views/admin/consecutive-records.hbs:29

src/views/admin/curator/edit.hbs:13

src/views/admin/curator/edit.hbs:94

src/views/admin/curator/galleries/edit.hbs:17

src/views/admin/curator/galleries/edit.hbs:34

src/views/admin/curator/galleries/list.hbs:21

src/views/admin/curator/galleries/list.hbs:76

src/views/admin/curator/galleries/list.hbs:77

src/views/admin/curator/galleries/list.hbs:83

src/views/admin/curator/job-status.hbs:18

src/views/admin/curator/job-status.hbs:44

src/views/admin/curator/job-status.hbs:53

src/views/admin/curator/job-status.hbs:57

src/views/admin/curator/list.hbs:11

src/views/admin/curator/list.hbs:114

src/views/admin/curator/list.hbs:117

src/views/admin/curator/list.hbs:43

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/curator/list.hbs:52

src/views/admin/curator/list.hbs:62

src/views/admin/curator/list.hbs:65

src/views/admin/curator/list.hbs:69

src/views/admin/curator/list.hbs:97

src/views/admin/dashboard.hbs:15

src/views/admin/dashboard.hbs:31

src/views/admin/dashboard.hbs:43

src/views/admin/dashboard.hbs:67

src/views/admin/dashboard.hbs:84

src/views/admin/email-log/index.hbs:45

src/views/admin/email-log/index.hbs:78

src/views/admin/email-log/index.hbs:79

src/views/admin/email-templates/edit.hbs:55

src/views/admin/email-templates/index.hbs:13

src/views/admin/emerging-vocabulary.hbs:18

src/views/admin/event-organizers/detail.hbs:55

src/views/admin/event-organizers/queue.hbs:22

src/views/admin/event-results/confirm.hbs:33

src/views/admin/event-results/discipline.hbs:39

src/views/admin/event-results/entry.hbs:48

src/views/admin/event-results/event.hbs:14

src/views/admin/event-results/event.hbs:22

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/event-results/event.hbs:35

src/views/admin/event-results/event.hbs:44

src/views/admin/event-results/index.hbs:28

src/views/admin/freestyle-modifier-add-confirm.hbs:28

src/views/admin/freestyle-modifier-add-confirm.hbs:49

src/views/admin/freestyle-modifier-edit.hbs:35

src/views/admin/freestyle-modifiers.hbs:62

src/views/admin/freestyle-notation-author.hbs:124

src/views/admin/freestyle-notation-author.hbs:44

src/views/admin/freestyle-notation-backlog.hbs:21

src/views/admin/freestyle-notation-backlog.hbs:79

src/views/admin/freestyle-notation-backlog.hbs:84

src/views/admin/freestyle-notation-drafts.hbs:51

src/views/admin/freestyle-notation-drafts.hbs:52

src/views/admin/freestyle-notation-drafts.hbs:71

src/views/admin/freestyle-record-edit.hbs:98

src/views/admin/freestyle-records.hbs:55

src/views/admin/freestyle-trick-edit.hbs:25

src/views/admin/freestyle-trick-edit.hbs:26

src/views/admin/freestyle-trick-edit.hbs:272

src/views/admin/freestyle-trick-publish.hbs:137

src/views/admin/freestyle-tricks.hbs:61

src/views/admin/historical-records/confirm.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/historical-records/correction.hbs:45

src/views/admin/historical-records/index.hbs:35

src/views/admin/historical-records/index.hbs:38

src/views/admin/honor-grants/action-confirm.hbs:29

src/views/admin/honor-grants/grant-confirm.hbs:15

src/views/admin/honor-grants/grant-confirm.hbs:32

src/views/admin/mailing-lists/compose.hbs:37

src/views/admin/mailing-lists/detail.hbs:24

src/views/admin/mailing-lists/detail.hbs:26

src/views/admin/mailing-lists/detail.hbs:92

src/views/admin/mailing-lists/form.hbs:43

src/views/admin/mailing-lists/index.hbs:11

src/views/admin/mailing-lists/index.hbs:29

src/views/admin/media-flags/index.hbs:29

src/views/admin/media-flags/index.hbs:46

src/views/admin/media-flags/index.hbs:47

src/views/admin/media-flags/index.hbs:51

src/views/admin/media-flags/index.hbs:58

src/views/admin/members/confirm.hbs:43

src/views/admin/members/index.hbs:30

src/views/admin/members/record.hbs:22

src/views/admin/members/record.hbs:302

src/views/admin/members/record.hbs:307

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/payments/detail.hbs:31

src/views/admin/payments/detail.hbs:40

src/views/admin/payments/detail.hbs:98

src/views/admin/payments/health.hbs:154

src/views/admin/payments/health.hbs:156

src/views/admin/payments/health.hbs:158

src/views/admin/payments/index.hbs:10

src/views/admin/payments/index.hbs:115

src/views/admin/payments/index.hbs:128

src/views/admin/payments/index.hbs:145

src/views/admin/payments/index.hbs:152

src/views/admin/payments/index.hbs:163

src/views/admin/payments/index.hbs:174

src/views/admin/payments/index.hbs:175

src/views/admin/payments/index.hbs:73

src/views/admin/payments/reconciliation.hbs:27

src/views/admin/payments/reconciliation.hbs:28

src/views/admin/payments/reconciliation.hbs:29

src/views/admin/payments/reconciliation.hbs:65

src/views/admin/payments/reconciliation.hbs:93

src/views/admin/payments/reconciliation.hbs:94

src/views/admin/payments/report.hbs:11

src/views/admin/payments/report.hbs:12

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/admin/payments/report.hbs:58

src/views/admin/payments/report.hbs:79

src/views/admin/payments/report.hbs:97

src/views/admin/payments/reports.hbs:47

src/views/admin/payments/reports.hbs:48

src/views/admin/payments/reports.hbs:49

src/views/admin/payments/reports.hbs:69

src/views/admin/payments/reports.hbs:87

src/views/admin/payments/reports.hbs:88

src/views/admin/system-health/index.hbs:186

src/views/admin/system-health/index.hbs:32

src/views/admin/system-health/index.hbs:64

src/views/admin/tags/confirm.hbs:31

src/views/admin/work-queue/dispute-revert-confirm.hbs:15

src/views/admin/work-queue/dispute-revert-confirm.hbs:42

src/views/admin/work-queue/index.hbs:221

src/views/admin/work-queue/index.hbs:240

src/views/admin/work-queue/index.hbs:294

src/views/admin/work-queue/index.hbs:68

src/views/admin/work-queue/index.hbs:71

src/views/admin/work-queue/index.hbs:82

src/views/admin/work-queue/link-help-confirm.hbs:19

src/views/admin/work-queue/link-help-confirm.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/clubs/country.hbs:54

src/views/clubs/country.hbs:6

src/views/clubs/create.hbs:131

src/views/clubs/create.hbs:19

src/views/clubs/create.hbs:24

src/views/clubs/detail.hbs:108

src/views/clubs/detail.hbs:123

src/views/clubs/detail.hbs:140

src/views/clubs/detail.hbs:170

src/views/clubs/detail.hbs:6

src/views/clubs/index.hbs:27

src/views/clubs/leave-confirm.hbs:24

src/views/clubs/leave-confirm.hbs:30

src/views/clubs/step-down-confirm.hbs:25

src/views/dev/persona-listing.hbs:75

src/views/dev/persona-listing.hbs:78

src/views/equipment/index.hbs:31

src/views/equipment/index.hbs:44

src/views/errors/error.hbs:13

src/views/events/index.hbs:16

src/views/events/index.hbs:23

src/views/events/index.hbs:34

src/views/events/year.hbs:17

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/events/year.hbs:23

src/views/freestyle/about.hbs:8

src/views/freestyle/add-analysis.hbs:14

src/views/freestyle/add-analysis.hbs:256

src/views/freestyle/by-the-numbers.hbs:12

src/views/freestyle/by-the-numbers.hbs:26

src/views/freestyle/combo-analysis.hbs:14

src/views/freestyle/combo-analysis.hbs:157

src/views/freestyle/competition.hbs:105

src/views/freestyle/competition.hbs:71

src/views/freestyle/competition.hbs:8

src/views/freestyle/concepts.hbs:103

src/views/freestyle/concepts.hbs:295

src/views/freestyle/concepts.hbs:300

src/views/freestyle/concepts.hbs:852

src/views/freestyle/concepts.hbs:857

src/views/freestyle/concepts.hbs:9

src/views/freestyle/concepts.hbs:910

src/views/freestyle/family-detail.hbs:12

src/views/freestyle/family-detail.hbs:26

src/views/freestyle/family-detail.hbs:66

src/views/freestyle/family-detail.hbs:68

src/views/freestyle/family-detail.hbs:72

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/family-detail.hbs:98

src/views/freestyle/glossary.hbs:10

src/views/freestyle/glossary.hbs:26

src/views/freestyle/glossary.hbs:28

src/views/freestyle/glossary.hbs:30

src/views/freestyle/glossary.hbs:34

src/views/freestyle/glossary.hbs:46

src/views/freestyle/history.hbs:43

src/views/freestyle/history.hbs:57

src/views/freestyle/history.hbs:74

src/views/freestyle/history.hbs:8

src/views/freestyle/history.hbs:86

src/views/freestyle/jobs-notation-article.hbs:8

src/views/freestyle/leaders.hbs:37

src/views/freestyle/leaders.hbs:8

src/views/freestyle/media.hbs:24

src/views/freestyle/modifier-family.hbs:18

src/views/freestyle/modifier-family.hbs:39

src/views/freestyle/modifier-family.hbs:63

src/views/freestyle/modifier-family.hbs:80

src/views/freestyle/modifier-family.hbs:94

src/views/freestyle/modifier-stub.hbs:12

src/views/freestyle/modifier-stub.hbs:33

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/modifier-stub.hbs:60

src/views/freestyle/modifier-stub.hbs:68

src/views/freestyle/observational.hbs:165

src/views/freestyle/observational.hbs:20

src/views/freestyle/operators.hbs:15

src/views/freestyle/operators.hbs:59

src/views/freestyle/partnerships.hbs:47

src/views/freestyle/partnerships.hbs:8

src/views/freestyle/partnerships.hbs:83

src/views/freestyle/records.hbs:65

src/views/freestyle/records.hbs:8

src/views/freestyle/records.hbs:83

src/views/freestyle/records.hbs:97

src/views/freestyle/search.hbs:46

src/views/freestyle/search.hbs:63

src/views/freestyle/search.hbs:8

src/views/freestyle/set-detail.hbs:123

src/views/freestyle/set-detail.hbs:134

src/views/freestyle/set-detail.hbs:136

src/views/freestyle/set-detail.hbs:161

src/views/freestyle/set-detail.hbs:167

src/views/freestyle/set-detail.hbs:17

src/views/freestyle/set-detail.hbs:60

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/set-detail.hbs:76

src/views/freestyle/sets-encyclopedia.hbs:163

src/views/freestyle/sets-encyclopedia.hbs:176

src/views/freestyle/sets-encyclopedia.hbs:185

src/views/freestyle/sets-encyclopedia.hbs:194

src/views/freestyle/sets-encyclopedia.hbs:203

src/views/freestyle/sets-encyclopedia.hbs:213

src/views/freestyle/sets-encyclopedia.hbs:37

src/views/freestyle/sets-encyclopedia.hbs:52

src/views/freestyle/start.hbs:12

src/views/freestyle/start.hbs:161

src/views/freestyle/trick-shell.hbs:47

src/views/freestyle/tricks.hbs:103

src/views/freestyle/tricks.hbs:157

src/views/freestyle/tricks.hbs:163

src/views/freestyle/tricks.hbs:170

src/views/freestyle/tricks.hbs:235

src/views/freestyle/tricks.hbs:248

src/views/freestyle/tricks.hbs:275

src/views/freestyle/tricks.hbs:309

src/views/freestyle/tricks.hbs:349

src/views/freestyle/tricks.hbs:354

src/views/freestyle/tricks.hbs:367

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/freestyle/tricks.hbs:378

src/views/freestyle/tricks.hbs:386

src/views/freestyle/tricks.hbs:40

src/views/freestyle/tricks.hbs:413

src/views/freestyle/tricks.hbs:66

src/views/freestyle/tricks.hbs:8

src/views/history/claim-hp-confirm.hbs:54

src/views/history/claim-hp-conflict.hbs:28

src/views/history/claim-unavailable.hbs:41

src/views/history/detail.hbs:57

src/views/history/detail.hbs:71

src/views/ifpa/index.hbs:30

src/views/ifpa/index.hbs:32

src/views/ifpa/roster.hbs:36

src/views/ifpa/roster.hbs:41

src/views/ifpa/roster.hbs:68

src/views/ifpa/roster.hbs:96

src/views/ifpa/roster.hbs:97

src/views/layouts/main.hbs:75

src/views/layouts/main.hbs:81

src/views/media/browse.hbs:43

src/views/media/browse.hbs:56

src/views/media/browse.hbs:67

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/media/gallery-item.hbs:12

src/views/media/gallery-item.hbs:13

src/views/media/gallery-item.hbs:14

src/views/media/gallery-item.hbs:17

src/views/media/gallery-item.hbs:57

src/views/media/gallery-item.hbs:65

src/views/media/gallery-item.hbs:69

src/views/media/gallery-item.hbs:73

src/views/media/gallery-item.hbs:79

src/views/media/gallery-item.hbs:87

src/views/media/index.hbs:19

src/views/media/member-galleries.hbs:16

src/views/media/member-galleries.hbs:17

src/views/media/member-galleries.hbs:19

src/views/members/contact-admin.hbs:40

src/views/members/delete-account-done.hbs:22

src/views/members/delete-account.hbs:22

src/views/members/delete-account.hbs:23

src/views/members/delete-account.hbs:58

src/views/members/galleries/edit.hbs:13

src/views/members/galleries/list.hbs:15

src/views/members/galleries/list.hbs:71

src/views/members/galleries/list.hbs:81

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

```
src/views/members/media/delete-confirm.hbs:24
src/views/members/media/edit.hbs:102
src/views/members/media/edit.hbs:90
src/views/members/payment-history.hbs:43
src/views/members/payment-history.hbs:96
src/views/members/profile-edit.hbs:30
src/views/members/profile.hbs:17
src/views/members/public-profile.hbs:40
src/views/members/questions.hbs:82
src/views/members/recurring-donation-cancel-confirm.hbs:28
src/views/net/index.hbs:48
src/views/partials/_gallery-current-items.hbs:40
src/views/partials/_gallery-tile.hbs:16
src/views/partials/_gallery-tile.hbs:22
src/views/partials/_gallery-tile.hbs:7
src/views/partials/_pager.hbs:16
src/views/partials/_pager.hbs:20
src/views/partials/_pager.hbs:8
src/views/partials/_set-empty-state.hbs:12
src/views/partials/_set-header.hbs:11
src/views/partials/_set-header.hbs:17
src/views/partials/_teaching-empty-state.hbs:16
src/views/partials/_teaching-empty-state.hbs:26
```

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/_teaching-empty-state.hbs:46

src/views/partials/_tier-benefit-notice.hbs:15

src/views/partials/back-link.hbs:5

src/views/partials/dictionary-trick-row.hbs:54

src/views/partials/dictionary-trick-row.hbs:60

src/views/partials/dictionary-trick-row.hbs:65

src/views/partials/dictionary-trick-row.hbs:68

src/views/partials/entity-media.hbs:6

src/views/partials/freestyle-modifier-advanced-reference.hbs:125

src/views/partials/freestyle-modifier-reference.hbs:103

src/views/partials/freestyle-modifier-reference.hbs:85

src/views/partials/gallery-edit-form.hbs:178

src/views/partials/glossary-family-card.hbs:72

src/views/partials/media-line.hbs:13

src/views/partials/media-line.hbs:14

src/views/partials/member-block-actions.hbs:22

src/views/partials/member-block-actions.hbs:43

src/views/partials/member-block-identity.hbs:24

src/views/partials/member-block-media.hbs:20

src/views/partials/member-block-media.hbs:21

src/views/partials/member-block-media.hbs:36

src/views/partials/member-block-media.hbs:37

src/views/partials/member-block-media.hbs:38

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/member-block-my-clubs.hbs:58

src/views/partials/member-block-my-clubs.hbs:67

src/views/partials/member-block-my-clubs.hbs:70

src/views/partials/member-block-my-clubs.hbs:9

src/views/partials/member-block-quick-actions.hbs:5

src/views/partials/member-block-search.hbs:47

src/views/partials/nav-links.hbs:6

src/views/partials/player-results.hbs:29

src/views/partials/player-results.hbs:35

src/views/partials/result-section.hbs:29

src/views/partials/set-detail-cross-links.hbs:11

src/views/partials/set-detail-cross-links.hbs:6

src/views/partials/set-detail-cross-links.hbs:8

src/views/partials/share-media-form.hbs:283

src/views/partials/simulated-email-card.hbs:33

src/views/partials/sport-section.hbs:21

src/views/partials/sport-section.hbs:46

src/views/partials/symbolic-related-topology.hbs:11

src/views/partials/trick-about.hbs:57

src/views/partials/trick-about.hbs:94

src/views/partials/trick-equivalent-readings.hbs:21

src/views/partials/trick-family.hbs:22

src/views/partials/trick-family.hbs:32

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/partials/trick-family.hbs:46

src/views/partials/trick-hero.hbs:21

src/views/partials/trick-pathways.hbs:24

src/views/partials/trick-pathways.hbs:36

src/views/partials/trick-pathways.hbs:48

src/views/partials/trick-progression.hbs:27

src/views/partials/trick-progression.hbs:43

src/views/partials/trick-quantity-ladder.hbs:19

src/views/partials/trick-records.hbs:25

src/views/partials/trick-records.hbs:41

src/views/partials/trick-related.hbs:19

src/views/partials/trick-related.hbs:21

src/views/partials/trick-relative-side.hbs:15

src/views/partials/trick-relative-side.hbs:25

src/views/partials/trick-similar.hbs:17

src/views/partials/trick-structural-facts.hbs:19

src/views/partials/trick-structural-facts.hbs:24

src/views/partials/trick-terminal-derived.hbs:21

src/views/partials/trick-terminal-derived.hbs:29

src/views/partials/trick-transform.hbs:29

src/views/partials/video-facade.hbs:13

src/views/payments/cancel.hbs:19

src/views/payments/donate.hbs:15

SCANNER RESULTS, VAR-IN-HREF, CONTINUED

src/views/payments/donate.hbs:92

src/views/payments/success.hbs:19

src/views/public/bap.hbs:22

src/views/public/hof.hbs:22

src/views/public/home.hbs:20

src/views/register/wizard/club-affiliations.hbs:20

src/views/register/wizard/complete.hbs:12

src/views/register/wizard/complete.hbs:21

src/views/register/wizard/legacy-claim.hbs:111

src/views/register/wizard/legacy-claim.hbs:50

src/views/rules/index.hbs:19

src/views/rules/index.hbs:28

unquoted-attribute-var 128 places, static analysis

MEDIUM

Detected a unquoted template variable as an attribute. If unquoted, a malicious actor could inject custom JavaScript handlers. To fix this, add quotes around the template expression, like this: "{{ expr }}".

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 128 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

src/views/admin/audit-log/index.hbs:20

src/views/admin/audit-log/index.hbs:28

src/views/admin/audit-log/index.hbs:36

src/views/admin/club-cleanup.hbs:16

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/club-cleanup.hbs:23

src/views/admin/curator/list.hbs:61

src/views/admin/curator/list.hbs:64

src/views/admin/curator/list.hbs:68

src/views/admin/email-log/index.hbs:18

src/views/admin/email-log/index.hbs:26

src/views/admin/email-templates/edit.hbs:38

src/views/admin/email-templates/edit.hbs:42

src/views/admin/emerging-vocabulary.hbs:62

src/views/admin/emerging-vocabulary.hbs:84

src/views/admin/event-results/discipline.hbs:21

src/views/admin/event-results/discipline.hbs:28

src/views/admin/event-results/discipline.hbs:29

src/views/admin/event-results/entry.hbs:30

src/views/admin/freestyle-modifier-edit.hbs:25

src/views/admin/freestyle-modifiers.hbs:34

src/views/admin/freestyle-notation-author.hbs:72

src/views/admin/freestyle-notation-author.hbs:83

src/views/admin/freestyle-notation-author.hbs:94

src/views/admin/freestyle-record-edit.hbs:25

src/views/admin/freestyle-record-edit.hbs:63

src/views/admin/freestyle-record-edit.hbs:73

src/views/admin/freestyle-records.hbs:22

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/freestyle-sources.hbs:26

src/views/admin/freestyle-trick-edit.hbs:125

src/views/admin/freestyle-trick-edit.hbs:129

src/views/admin/freestyle-trick-edit.hbs:144

src/views/admin/freestyle-trick-edit.hbs:173

src/views/admin/freestyle-trick-edit.hbs:181

src/views/admin/freestyle-trick-edit.hbs:218

src/views/admin/freestyle-trick-edit.hbs:259

src/views/admin/freestyle-trick-edit.hbs:62

src/views/admin/freestyle-trick-edit.hbs:66

src/views/admin/freestyle-trick-edit.hbs:75

src/views/admin/freestyle-trick-publish.hbs:103

src/views/admin/freestyle-trick-publish.hbs:84

src/views/admin/freestyle-tricks.hbs:20

src/views/admin/freestyle-tricks.hbs:28

src/views/admin/historical-records/correction.hbs:26

src/views/admin/mailing-lists/form.hbs:33

src/views/admin/members/record.hbs:124

src/views/admin/members/record.hbs:184

src/views/admin/members/record.hbs:204

src/views/admin/members/record.hbs:210

src/views/admin/members/record.hbs:214

src/views/admin/members/record.hbs:218

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/admin/members/record.hbs:222

src/views/admin/members/record.hbs:226

src/views/admin/members/record.hbs:230

src/views/admin/payments/index.hbs:126

src/views/admin/payments/index.hbs:18

src/views/admin/payments/index.hbs:28

src/views/admin/payments/index.hbs:49

src/views/admin/payments/reconciliation.hbs:37

src/views/admin/system-parameters/index.hbs:45

src/views/admin/work-queue/index.hbs:128

src/views/admin/work-queue/index.hbs:136

src/views/admin/work-queue/index.hbs:259

src/views/admin/work-queue/index.hbs:261

src/views/admin/work-queue/index.hbs:268

src/views/clubs/country.hbs:45

src/views/clubs/create.hbs:102

src/views/events/index.hbs:16

src/views/events/index.hbs:23

src/views/events/index.hbs:34

src/views/ifpa/roster.hbs:41

src/views/layouts/main.hbs:48

src/views/layouts/main.hbs:52

src/views/media/gallery-item.hbs:57

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/media/gallery-item.hbs:9

src/views/members/contact-admin.hbs:24

src/views/members/contact-admin.hbs:26

src/views/members/profile-edit.hbs:112

src/views/members/profile-edit.hbs:139

src/views/members/profile-edit.hbs:164

src/views/members/profile-edit.hbs:181

src/views/members/profile-edit.hbs:185

src/views/members/profile-edit.hbs:189

src/views/members/profile-edit.hbs:196

src/views/members/profile-edit.hbs:222

src/views/members/profile-edit.hbs:241

src/views/members/profile-edit.hbs:248

src/views/members/profile-edit.hbs:249

src/views/members/profile-edit.hbs:250

src/views/members/profile-edit.hbs:260

src/views/members/profile-edit.hbs:99

src/views/members/questions.hbs:39

src/views/members/questions.hbs:43

src/views/members/questions.hbs:59

src/views/partials/_gallery-current-items.hbs:30

src/views/partials/_gallery-current-items.hbs:55

src/views/partials/_pager.hbs:16

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/partials/_tag-filter-bar.hbs:51

src/views/partials/demo-video.hbs:6

src/views/partials/gallery-edit-form.hbs:105

src/views/partials/gallery-edit-form.hbs:88

src/views/partials/gallery-edit-form.hbs:95

src/views/partials/gallery-edit-form.hbs:96

src/views/partials/gallery-edit-form.hbs:97

src/views/partials/media-line.hbs:11

src/views/partials/nav-links.hbs:6

src/views/partials/region-picker.hbs:11

src/views/partials/region-picker.hbs:13

src/views/partials/region-picker.hbs:16

src/views/partials/region-picker.hbs:21

src/views/partials/share-media-form.hbs:131

src/views/partials/share-media-form.hbs:15

src/views/partials/share-media-form.hbs:19

src/views/partials/share-media-form.hbs:20

src/views/partials/share-media-form.hbs:22

src/views/partials/share-media-form.hbs:231

src/views/partials/share-media-form.hbs:240

src/views/partials/share-media-form.hbs:254

src/views/partials/share-media-form.hbs:65

src/views/partials/sport-section.hbs:46

SCANNER RESULTS, UNQUOTED-ATTRIBUTE-VAR, CONTINUED

src/views/partials/video-facade.hbs:16

src/views/partials/video-facade.hbs:17

src/views/partials/wizard-birth-date-correction.hbs:21

src/views/register/wizard/personal-details.hbs:27

src/views/register/wizard/personal-details.hbs:50

src/views/register/wizard/personal-details.hbs:67

src/views/register/wizard/personal-details.hbs:71

src/views/register/wizard/personal-details.hbs:75

src/views/register/wizard/personal-details.hbs:92

insecure-hash-algorithm-sha1 **19 places, static analysis** MEDIUM

Detected SHA1 hash algorithm which is considered insecure. SHA1 is not collision resistant and is therefore not suitable as a cryptographic signature. Use SHA256 or SHA3 instead.

THE FIX

Change the code at each of the 19 places listed. Replace the weak algorithm with a current one, such as AES-GCM for encryption or SHA-256 for hashing.

freestyle/loaders/22_qc_trick_dictionary.py:157

legacy_data/clubs/scripts/01_build_club_person_universe.py:25

legacy_data/clubs/scripts/06_cutover_pre_populated_clubs.py:203

legacy_data/clubs/scripts/07_load_bootstrap_leaders.py:113

legacy_data/clubs/scripts/07a_load_bootstrap_leader_signals.py:103

legacy_data/event_results/scripts/08_load_mvfp_seed_full_to_sqlite.py:44

legacy_data/event_results/scripts/09_load_enrichment_to_sqlite.py:61

legacy_data/legacy_mirror/create_mirror_footbag_org.py:3219

legacy_data/legacy_mirror/create_mirror_footbag_org.py:3297

SCANNER RESULTS, INSECURE-HASH-ALGORITHM-SHA1, CONTINUED

```
legacy_data/persons/provisional/scripts/01_build_provisional_persons_master.py:24
legacy_data/persons/provisional/scripts/02_build_provisional_identity_candidates.py:25
legacy_data/persons/scripts/05_build_persons_master.py:46
legacy_data/scripts/load_club_members_seed.py:40
legacy_data/scripts/load_clubs_seed.py:91
scripts/promote_snippet_candidates.py:231
scripts/seed_email_templates.py:67
scripts/seed_fh_curator.py:152
scripts/seed_fh_curator.py:162
scripts/seed_fh_curator.py:694
```

dynamic-urllib-use-detected **5 places, static analysis** MEDIUM

Detected a dynamic value being used with urllib. urllib supports 'file://' schemes, so a dynamic value controlled by a malicious actor may allow them to read arbitrary files. Audit uses of urllib calls to ensure user data cannot control the URLs, or consider using the 'requests' library instead.

THE FIX

Change the code at each of the 5 places listed so the dynamic-urllib-use-detected rule no longer finds it.

```
freestyle/scripts/18_scrape_footbag_org_moves.py:189
legacy_data/member_data_scripts/diff_live_honor_rosters.py:84
legacy_data/scripts/generate_world_map_svg.py:58
scripts/acquire_footbag_org_demos.py:85
scripts/acquire_footbag_org_demos.py:93
```

SCANNER RESULTS, CONTINUED

`requests` 3 advisories in 2.31.0, dependency advisories

MEDIUM

Installed: 2.31.0, the repository's own dependency

THE FIX

Upgrade requests from 2.31.0 to 2.33.0 to fix all 3.

`CVE-2024-35195, fixed in 2.32.0` MEDIUM

requests: subsequent requests to the same host ignore cert verification. Requests is a HTTP library. Prior to 2.32.0, when making requests through a Requests Session, if the first request is made with verify=False to disable cert verification, all subsequent requests to the same host will continue to ignore cert verification regardless of changes to the value of verify.

`CVE-2024-47081, fixed in 2.32.4` MEDIUM

requests: Requests vulnerable to .netrc credentials leak via malicious URLs. Requests is a HTTP library. Due to a URL parsing issue, Requests releases prior to 2.32.4 may leak .netrc credentials to third parties for specific maliciously-crafted URLs. Users should upgrade to version 2.32.4 to receive a fix.

`CVE-2026-25645, fixed in 2.33.0` MEDIUM

requests: Security bypass due to predictable temporary file creation. Requests is a HTTP library. Prior to version 2.33.0, the requests.utils.extractzippedpaths() utility function uses a predictable filename when extracting files from zip archives into the system temporary directory. If the target file already exists, it is reused without validation.

`var-in-script-tag` 2 places, static analysis

MEDIUM

Detected a template variable used in a script tag. Although template variables are HTML escaped, HTML escaping does not always prevent cross-site scripting (XSS) attacks when used directly in JavaScript. If you need this data on the rendered page, consider placing it in the HTML portion (outside of a script tag). Alternatively, use a JavaScript-specific encoder, such as the one available in OWASP ESAPI. For Django, you may also consider using the 'json_script' template tag and retrieving the data in your script by using the element ID (e.g., `document.getElementById`).

RISK IF LEFT

An attacker can run script in a user's browser and act as that user, reading their session too.

THE FIX

Change the code at each of the 2 places listed. Escape the value for where it lands in the page, or clean it with a library such as DOMPurify before inserting it as HTML.

`src/views/clubs/index.hbs:8`

`src/views/partials/share-media-form.hbs:286`

SCANNER RESULTS, CONTINUED

glob 1 advisory in 13.0.6, dependency advisories

MEDIUM

Installed: 13.0.6, brought in by express-handlebars 8.0.6

RISK IF LEFT

A crafted request can use enough resources to slow or stop the service.

THE FIX

Version 14.0.2 fixes it. glob 13.0.6 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses glob 14.0.2 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "glob": "^14.0.2" } }. Moving from 13.0.6 to 14.0.2 is a breaking step under semantic versioning, so forcing it can break express-handlebars. Test before shipping.

CVE-2026-118773, fixed in 14.0.2 — MEDIUM

glob: Denial of Service (DoS) via incomplete traversal cancellation. Glob matches files using patterns the shell uses. From 9.0.0 until 14.0.2, abort branches in src/walker.ts, including GlobUtil.walkCB(), GlobUtil.walkCB2(), GlobUtil.walkCBSync(), and GlobUtil.walkCB2Sync(), invoke the callbacks without returning.

idna 1 advisory in 3.11, dependency advisories

MEDIUM

Installed: 3.11, the repository's own dependency

RISK IF LEFT

A crafted input can make a pattern match run for a very long time, stalling the service.

THE FIX

Upgrade idna from 3.11 to 3.15 to fix it.

CVE-2026-45409, fixed in 3.15 — MEDIUM

python-idna: idna: Denial of Service via specially crafted long inputs. Internationalized Domain Names in Applications (IDNA) for Python provides support for Internationalized Domain Names in Applications (IDNA) and Unicode IDNA Compatibility Processing.

minimatch 1 advisory in 10.2.5, dependency advisories

MEDIUM

Installed: 10.2.5, brought in by express-handlebars 8.0.6

THE FIX

Version 11.0.1 fixes it. minimatch 10.2.5 comes in through express-handlebars 8.0.6. Upgrade it to a release that uses minimatch 11.0.1 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express-handlebars": { "minimatch": "^11.0.1" } }. Moving from 10.2.5 to 11.0.1 is a breaking step under semantic versioning, so forcing it can break express-handlebars. Test before shipping.

SCANNER RESULTS, MINIMATCH, CONTINUED

CVE-2026-118764, fixed in 11.0.1 — MEDIUM

minimatch: Denial of Service via crafted glob pattern expansion. minimatch is a minimal matching utility for converting glob expressions into JavaScript RegExp objects. Starting in 7.0.0 and prior to 11.0.1, src/index.ts implements firstPhasePreProcess() so that, at optimizationLevel 2 or higher, it repeatedly expands attacker-controlled /..

pytest 1 advisory in 8.3.3, dependency advisories — MEDIUM

Installed: 8.3.3, the repository's own dependency

THE FIX

Upgrade pytest from 8.3.3 to 9.0.3 to fix it. Moving from 8.3.3 to 9.0.3 is a breaking step under semantic versioning, so check the release notes before shipping it.

CVE-2025-71176, fixed in 9.0.3 — MEDIUM

pytest: Denial of Service or Privilege Escalation via insecure temporary directory handling. pytest through 9.0.2 on UNIX relies on directories with the /tmp/pytest-of-{user} name pattern, which allows local users to cause a denial of service or possibly gain privileges.

qs 1 advisory in 6.16.0, dependency advisories — MEDIUM

Installed: 6.16.0, brought in by express 4.22.2

RISK IF LEFT

The code doesn't catch an unexpected error, so a crafted request can crash the service.

THE FIX

Version 6.16.1 fixes it. qs 6.16.0 comes in through express 4.22.2. Upgrade it to a release that uses qs 6.16.1 or later, and if none does yet, force it up with an override in package.json, "overrides": { "express": { "qs": "^6.16.1" } }.

CVE-2026-110816, fixed in 6.16.1 — MEDIUM

qs: Denial of Service via unhandled exception during array serialization. qs.stringify with arrayFormat: 'comma' throws TypeError: Cannot convert object to primitive value when an array element cannot be coerced to a string, such as an object with an own non-callable toString ({ "toString": "x" }) or a null-prototype object.